

Sicurezza

CdL in Informatica – L31

Lezione L10 Network Security

Prof. Emiliano Casalicchio
Department of Computer Science
Sapienza University of Rome



SAPIENZA
UNIVERSITÀ DI ROMA



Topics

- Basic concepts
- Threats to Network Communication
- Wireless network security
- DoS e DDoS
- Cryptography in Network Security
- Firewalls
- IDS e IDPS



Basic concepts



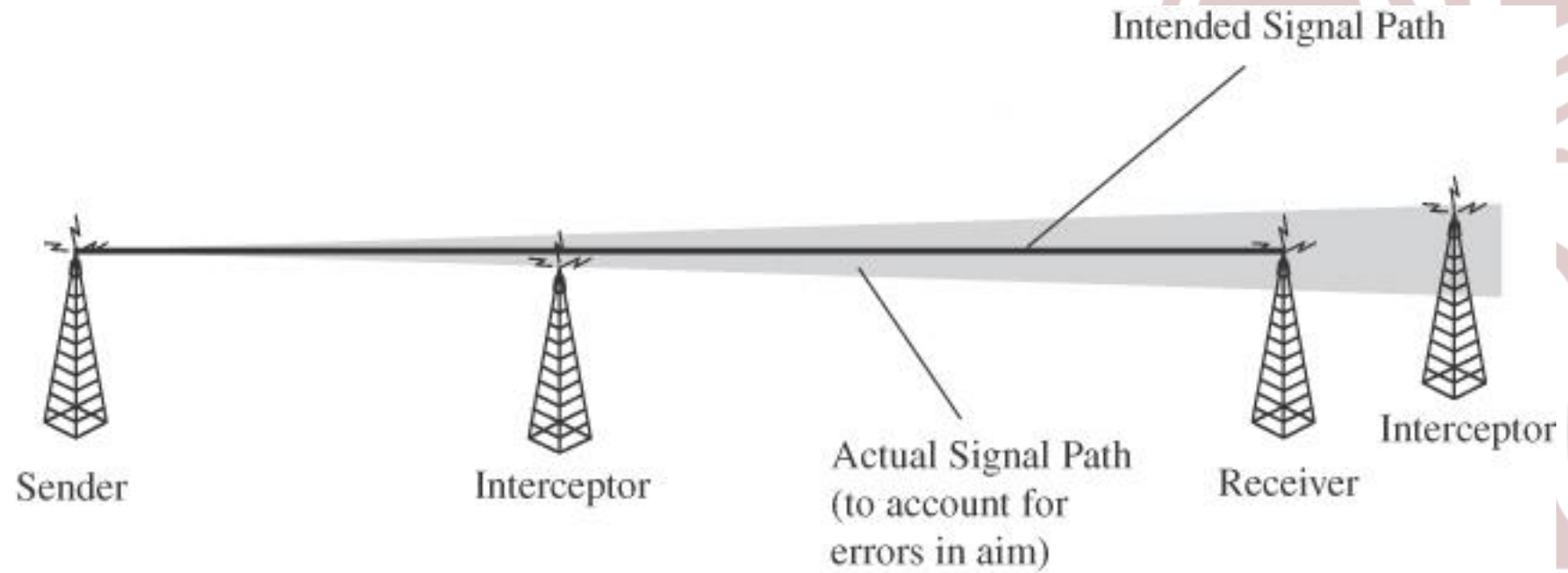
Interception (Eavesdropping)

- Sniffing
 - Packet sniffer is a device that retrieve all packets on its LAN
 - A reprogrammed NIC which reinject packets in the LAN after capturing the content
- Radiation
 - read radiated signals without making physical contact with the cable
 - for the attack to work, **the intruder must be fairly close** to the cable
- Cable Splicing
 - Cutting the cable to insert a sniffer
- Optical Fiber
 - Make impossible radiation and almost impossible Cable Splicing



Interception (cont'd)

- Microwave (WiFi)
 - A microwave signal is usually not shielded or isolated to prevent interception



Interception (cont'd)

- Satellite Communication
 - LEO, MEO or GEO
 - Broadcast footprint is wide; allow interception without detection



Interception - Summary

Medium	Strengths	Weaknesses
Wire	• Widely used • Inexpensive to buy, install, maintain	• Susceptible to emanation • Susceptible to physical wiretapping
Optical fiber	• Immune to emanation • Difficult to wiretap	• Potentially exposed at connection points
Microwave	• Strong signal, not seriously affected by weather	• Exposed to interception along path of transmission • Requires line of sight location • Signal must be repeated approximately every 50 km
Other radio wave technologies, including WiFi, Bluetooth, near field communication and cellular telephone communication	• Widely available • Built into many computers and devices	• Signal degrades over distance; suitable for short range (distance varies by technology) • Signal interceptable in circular pattern around transmitter
Satellite	• Strong signal • Useful in remote locations	• Delay due to distance signal travels up and down • Signal exposed over wide area at receiving end

Network Security Attacks



Threats to Network Communication

Types of Harm (renaming)

- *Interception* → **eavesdropping (wiretapping)**
- *Modification* → **integrity failures (data corruption)**
- *Interruption* → **Denial of Service**



Interception countermeasures

- Encryption is the strongest and most commonly used
- physical security (protecting the communications lines themselves)
- dedicated lines
- controlled routing (ensuring that a communication travels only along certain paths)



Vulnerabilities to Interception

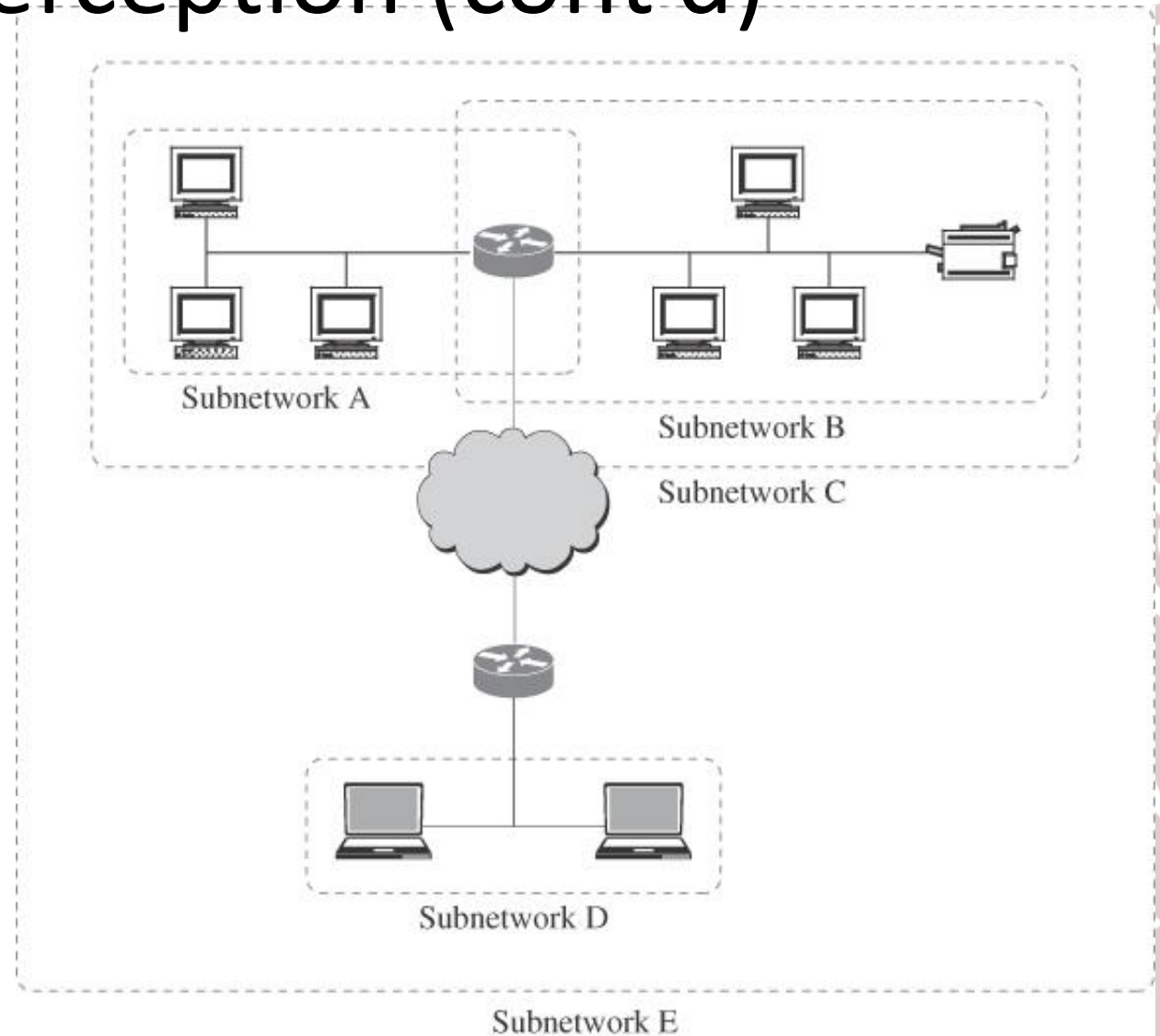
- Anonymity
- Multiple points of access
- Resource sharing
- System complexity
- multiple paths for communication



Vulnerabilities to Interception (cont'd)

Unknown perimeter

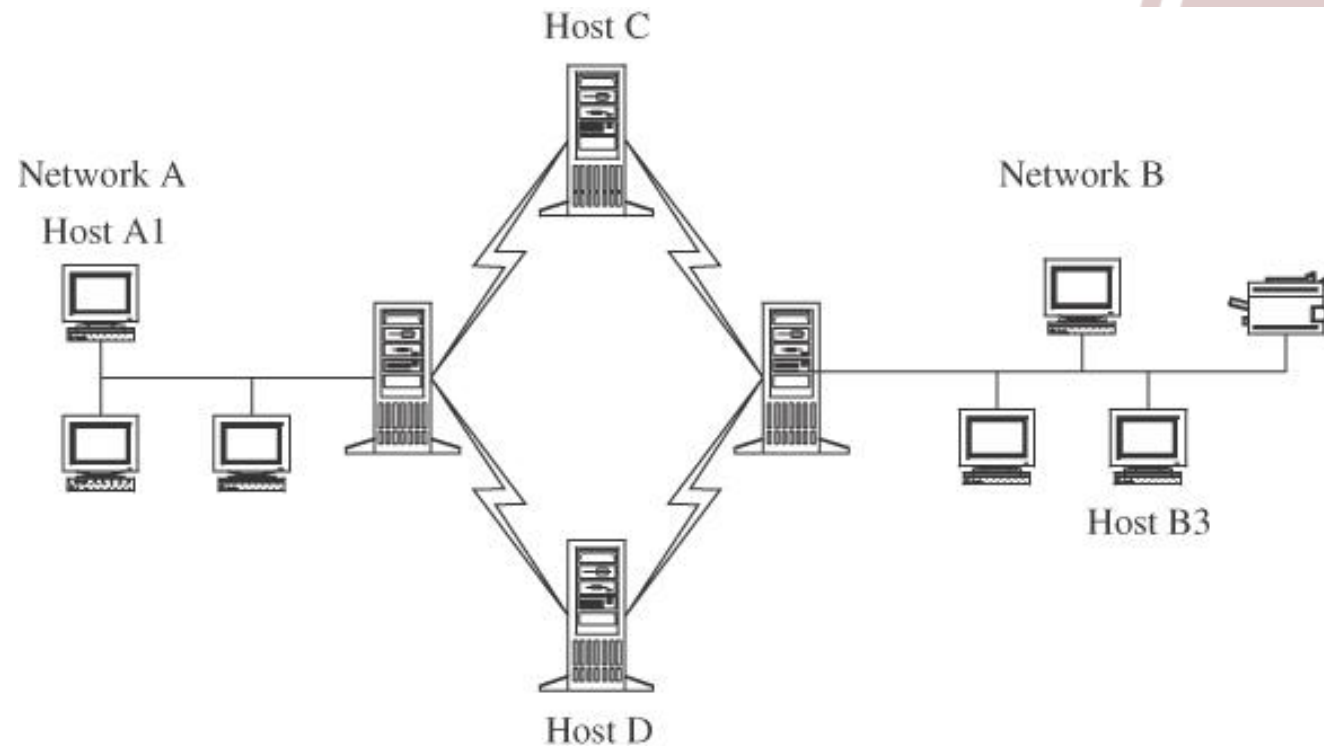
- Difficult to define the right perimeter
- a new hosts can be added to the network. Every network node must be able to react to the possible presence of new, untrustable hosts



Vulnerabilities to Interception (cont'd)

Unknown Paths

- Network users seldom have control over the routing of their messages.
- Inability to control routing is a factor in the interception



Data Corruption

A communication will be changed during transmission

- modifying data en route (**Modification attack**)
- crafting new content (**Insertion attack**)
- repeating a previous communication (**Replay attack**)



Modification attacks

- Sequencing
 - sequencing error occurs when a later fragment of a data stream arrives before a previous one
 - TCP ensure the proper ordering of traffic. However, application programs do not always detect or correct sequencing problems within the data stream
- Substitution
 - by splicing a piece from one communication into another
 - easiest to carry out with formatted communications (the attacker know which field should be modified to change the meaning)
 - Encryption/integrity check are the obvious countermeasures



Reply attack

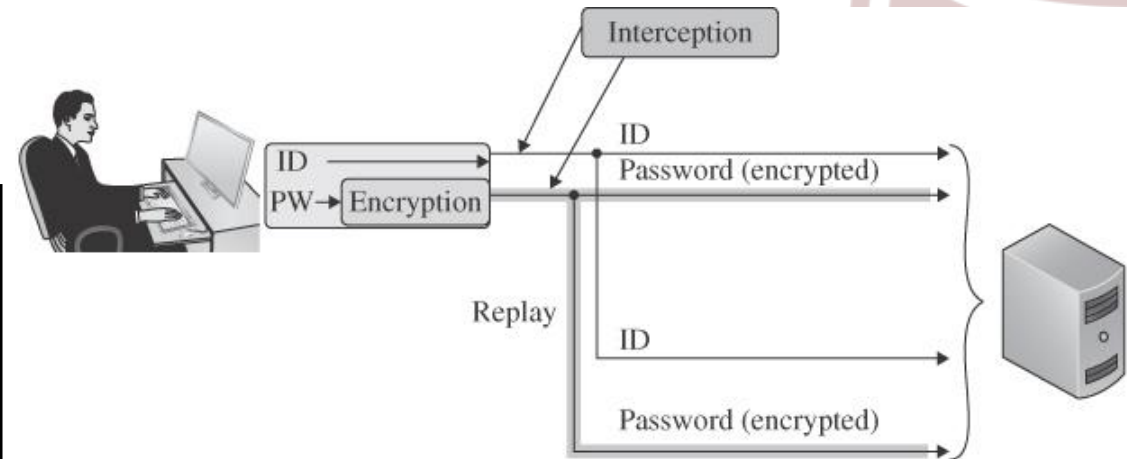
Legitimate data are intercepted and reused, generally without modification

No need to know the content or format of a transmission; can succeed on encrypted data without altering or breaking the encryption

- Suppose the user's card number, PIN, transaction amount, and merchant's identifier are bound into a single encrypted message - The message can be replied twice obtaining two transactions
- The authentication example
 - With ID & Password
 - With cookies

Defense

- sequence numbers
- recipient keeps the last message number received and checks each incoming message to ensure that its number is greater than the previous message received



Interruption: Loss of Service

- HW failures
 - Network design incorporates redundancy to counter hardware failures.
- Routing
 - Routing supports efficient resource use and quality of service. Misused, it can cause denial of service
 - Facebook cascading failure (2021)
 - BGP erroneous reconfiguration command (rather than excluding a portion of the network the whole FB network was hidden)
 - Audit system didn't work
 - Network management performed remotely (but the network was inaccessible)
 - Physical location was inaccessible because the badge authentication was network based
- Excessive Demand
- Component failure induced by malware



Port Scanning

- Mapping the topology and hardware and software components of a network segment
- A first step in an attack, a probe, to determine what further attacks might succeed
 - **port scanner**, a program that, for a particular internet (IP) address, reports which ports respond to queries and which of several known vulnerabilities seem to be present
 - **common vulnerabilities and exposures**, or **CVE (MITRE)**
- The Nmap scanner given an IP address reports all open ports, the service each supports, and the owner (user ID) of the daemon providing the service.



Hints from Port Scanning

- A manual scanning attempt on POP server

```
CL: telnet incoming.server.net 110
SV: +OK Messaging Multiplexor (Sun Java(tm) System Messaging Server
    6.2-6.01 (built Apr  3 2006))
    <4d3897ff.11ec04f8@vms108.mailsrvcs.net>
CL: user v1
SV: +OK password required for user v1@server.net
CL: pass pl
SV: -ERR [AUTH] Authentication failed
CL: quit
SV: +OK goodbye
```

The service is UP, the server version is know, a user v1 exist

Hints from a Nmap scan

- which standard ports or services are running and responding on the target system
- what operating system is installed on the target system
- what applications and versions of applications are present

```
Nmap scan report
192.168.1.1 / somehost.com (online) ping results
address: 192.168.1.1 (ipv4)
hostnames: somehost.com (user)
The 83 ports scanned but not shown below are in state: closed
```

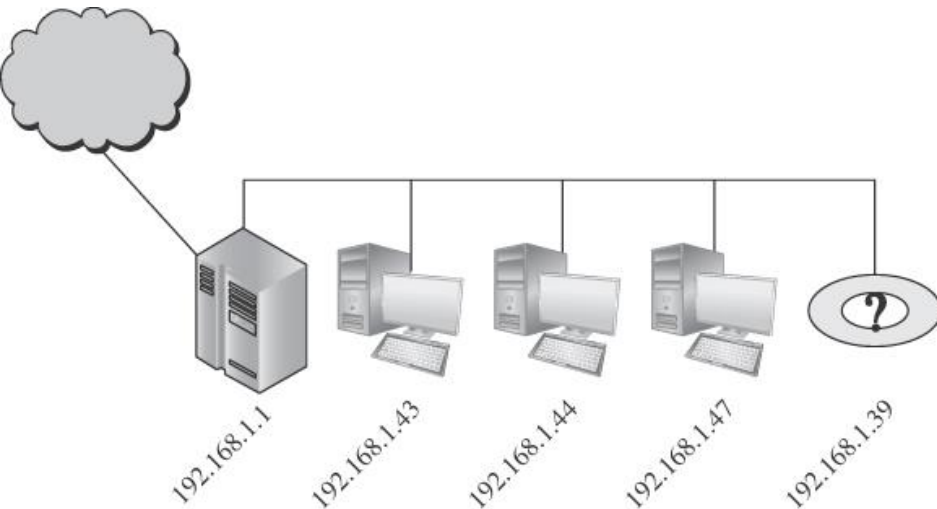
Port	State	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	ProFTPD	1.3.1	
22	tcp	filtered	ssh			
25	tcp	filtered	smtp			
80	tcp	open	http	Apache	8.2.3	(CentOS)
106	tcp	open	pop3pw	poppassd		
110	tcp	open	pop3	pop3d		
111	tcp	filtered	rpcbind			
113	tcp	filtered	auth			
143	tcp	open	imap	imapd	17.3	
443	tcp	open	http	Apache	8.2.3	(CentOS)
465	tcp	open	unknown			
646	tcp	filtered	ldp			
993	tcp	open	imap	imapd	17.3	
995	tcp	open				
2049	tcp	filtered	nfs			
3306	tcp	open	mysql	MySQL	5.0.45	
8443	tcp	open	unknown			

```
34 sec. scanned
1 host(s) scanned
1 host(s) online
0 host(s) offline
```



Hints from a Nmap scan on a network

- Because the latency time for all devices is similar, they are probably on the same network segment



```
Starting Nmap 5.21 ( http://nmap.org ) at ****-**-** 12:32 Eastern Daylight Time
```

```
Nmap scan report for router (192.168.1.1)
Host is up (0.00s latency).
MAC Address: 00:11:22:33:44:55 (Brand 1)
```

```
Nmap scan report for computer (192.168.1.39)
Host is up (0.78s latency).
MAC Address: 00:22:33:44:55:66 (Brand 2)
```

```
Nmap scan report computer (192.168.1.43)
Host is up (0.010s latency).
MAC Address: 00:11:33:55:77:99 (Brand 3)
```

```
Nmap scan report for unknown device 192.168.1.44
Host is up (0.010s latency).
MAC Address: 00:12:34:56:78:9A (Brand 4)
```

```
Nmap scan report for computer (192.168.1.47)
Host is up.
```

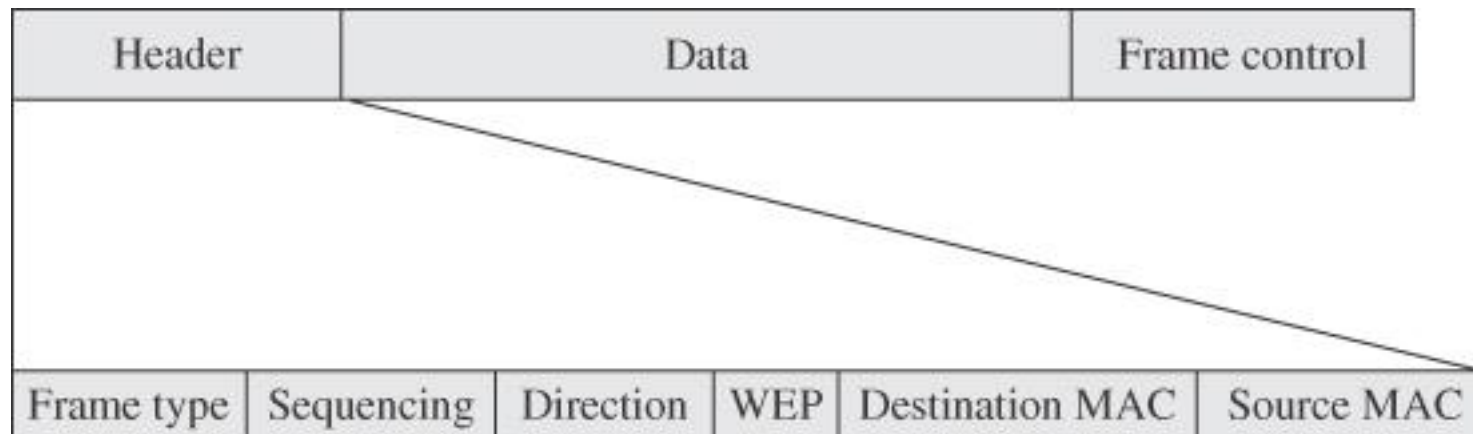
Harm of port scanners

- Are they a threat?
 - Not really, because the openings they report can be detected with or without port scans.
- Should they be prohibited in some way?
 - It is probably too late for that action, especially because any competent programmer with a rudimentary knowledge of network protocols could easily write a basic one
- Port scanners do not cause denial of service or any other network failure, but they do facilitate and often precipitate it
 - Network and vulnerability scanners can be used positively for management and administration and negatively for attack planning



Wireless security: Background

- Each WiFi data unit is called a **frame**
- Each frame contains three fields:
 - **MAC header**,
 - **payload**, and
 - **FCS (frame check sequence)**



Background: MAC header

- Contains fixed-sized fields, including
 - frame type: control, management, or data
 - ToDS, FromDS: direction of this frame: to or from the access point (called the distribution system)
 - fragmentation and order control bits
 - WEP (wired equivalency privacy) bit: encryption, described shortly
 - up to four MAC addresses (physical device identifiers): sender and receiver's addresses, plus two optional addresses for traffic filtering points



Background: Management frame

Management frame type

- *Beacon*. Each access point periodically sends a **beacon frame** to announce its presence and relay information, such as timestamp, identifier, and other parameters regarding the access point
- *Authentication*. A NIC initiates a request to interact with an access point by sending its identity in an **authentication frame (deauthentication frame to terminate)**
- Association request and response. Following authentication, a NIC requests an access point to establish a session
 - the NIC and access point exchange information about their capabilities and agree on parameters of their interaction.
 - an important part of establishing the association is agreeing on encryption.



Background: SSID

- A **Service Set Identifier**, or **SSID**, is the identification of an access point
- The SSID is the identifier the access point broadcasts in its beacon, and the ongoing link ties an associated NIC's communications to the given access point
- need to be unique in a given area to distinguish one wireless network from another
 - most factory defaults are a serial number unique to the device



WiFi Vulnerabilities

- Confidentiality
- Integrity
 - the attacker cannot readily receive something from the client, modify it, and transmit the modified version before the client's original signal gets to the server
 - An attacker can take over a communication stream by using strong signal
 - WiFi radio receivers that receive two signals prefer the stronger one



WiFi Vulnerabilities: Availability

- HW – SW failure
- Slow service
 - Interference on the signal cause by physical events
 - Loss of packets → delay for retransmission
 - Overload - demand for service exceeds the capacity of the receiving end
- **rogue network connection** – Public Hot spots
 - although service is available, the security of that service may be limited



Unauthorized WiFi Access

Steps of WiFi access protocol

1. The access point broadcasts its availability by sending a beacon, an invitation for devices to connect with it.
2. A device's NIC responds with a request to authenticate, which the access point accepts.
3. The device's NIC requests establishment of an association, which the access point negotiates and accepts

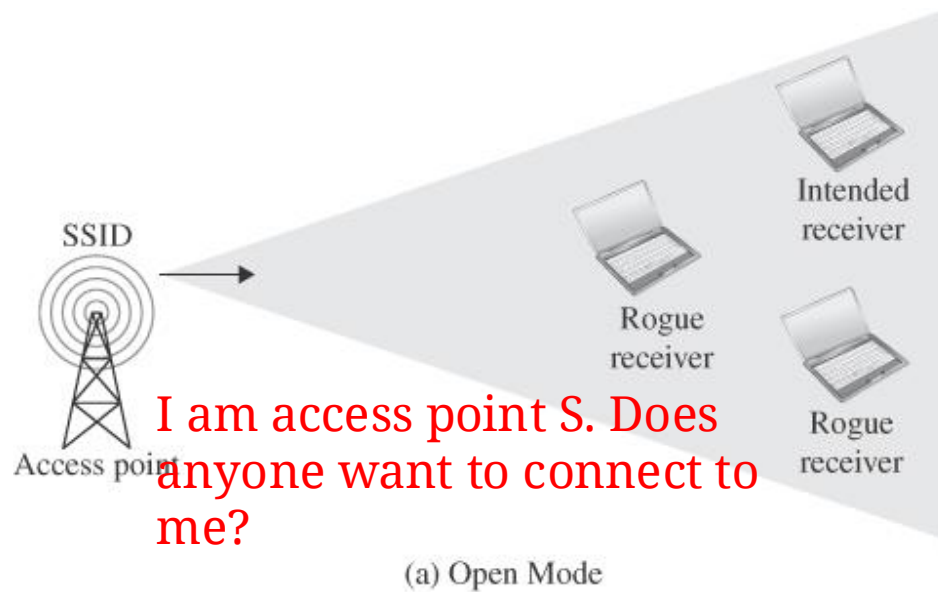
Threats can occur at each of these points

- In step 1, anyone can pick up and reply to a broadcast beacon.
- In step 2, the authentication is not rigorous; in basic WiFi mode, the access point accepts any device, without authentication.
- In step 3, any access point can accept an association with any device

Countermeasure can apply to each step



WiFi Protocol Weaknesses



Open Mode – The client chose the SSID

- Client not constantly visible

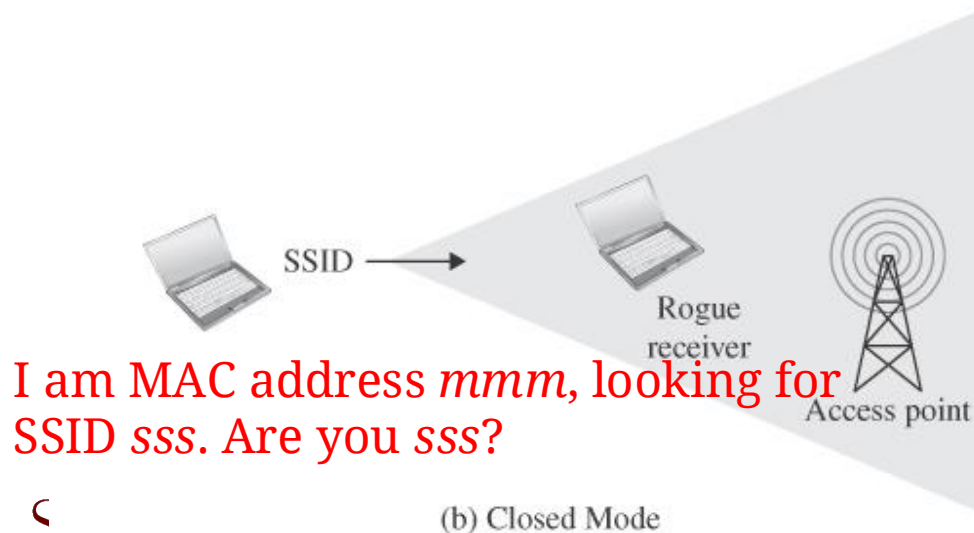
Closed Mode – The client become a beacon, sending a continuing series of messages

- a rogue malicious host can learn the expected values needed to impersonate an access point to which the client hopes to connect

The SSID is in every packet; seldom change; info reusable for an attack

A better protocol design:

- access point and the associating device establish a shared data value to be used during one association only.



Authentication in Wireless Networks

- Access points can manage lists of MAC addresses of devices with which they will accept connections.
 - Thus, authentication in step 2 could be accomplished by accepting only devices on the positive accept list.
- **MAC spoofing**
 - An operating system can send any address as if it were the MAC address of a NIC.
 - one device impersonates another, thereby assuming another device's communication session
- If a rogue process has intercepted an SSID and spoofed a MAC address, the two best points of access control have been lost
- Vulnerable access point reply to any frame also if an association has been established before, i.e. SSID and auth passed



WEP (Wired Equivalent Privacy)

- Intended as a way for wireless communication to provide privacy equivalent to conventional wired communications
- An example of failed countermeasure meant **to provide users immunity to eavesdropping and impersonation attacks**
- WEP uses a **shared encryption key** (client -- access point)
- To authenticate a user, the access point
 - sends a random number (RN) to the client
 - the client encrypts RN using the shared key and returns to the access point.
 - From that moment on, the client and access point are authenticated and can communicate using their shared encryption key.



WEP - Weak Encryption Key

- 64- or 128-bit encryption key, but each key begins with a 24-bit initialization vector (IV) -- actual key length to 40 or 104 bits
- Result in a long passphrase 16 or 32 symbols
- Passphrase stored in the client and access point
 - Guessable passphrases are used
 - Passphrase not changed often
- A dedicated attacker who can monitor a large amount of wireless network traffic will collect many data points from which to deduce a key.



WEP - Weak Encryption Algorithm

- Use RC4 to generate a long sequence of random numbers, called the key sequence, derived from the 24-bit initialization vector (IV) and the 40-bit key
- WEP combines the key sequence with the data using an exclusive-OR function
 - if the attacker can guess the decrypted value of any single encrypted frame, feeding that value into the exclusive-OR function reveals that segment of the key sequence
- The same key sequence is reused for all messages, so the segment will repeat at the same point
- The IV is communicated as plaintext, so an attacker can intercept it for an exhaustive key search attack



WEP – other weakness

- Initialization Vector Collisions
 - 24 bits cycle in a predictable pattern until all 24-bit patterns have been used – 16 million of iterations (testable in few min)
 - In practice, certain initialization vector values get caught in the loop and never change, while others do not cycle through all 16 million 24-bit patterns
- Faulty Integrity Check
 - Weak integrity check used to demonstrate whether a frame arrived intact or some bits had been lost or accidentally changed in transmission
- No Authentication
 - Any device that can name the correct SSID and present the correct MAC address is assumed to be legitimate



WPA (WiFi Protected Access)

- Non-Static Encryption Key
 - Uses a key change approach, called Temporal Key Integrity Program (TKIP); **the encryption key is changed automatically on each packet**
 - Establish **a new key for each session**. The access point (the authenticator) and the connecting device (the supplicant) create and exchange keys for confidentiality and integrity that are unique to the association session
- Authentication
 - Employs the Extensible Authentication Protocol (EAP) by which authentication can be done by password, token, certificate, etc...
- Strong Encryption
 - Adds AES, although RC4 is also still supported to maintain compatibility
- Integrity Protection
 - Uses a 64-bit integrity check that is encrypted



WPA – Session Initialization

Three protocol steps:

- authentication,
- a four-way handshake
 - to ensure that the client can generate cryptographic keys and to generate and install keys for both encryption and integrity on both ends
- an optional group key handshake
 - for multicast communication



Attacks on WPA: Man-in-the-Middle

- The attack succeeds by means of a MAC address spoofing attack.
- During the association sequence between a device and an access point, the device presents credentials to authenticate, and the access point sends a message confirming the authentication.
- At that point, **the malicious man-in-the-middle changes its MAC address to that of the access point and sends the device a request to disassociate.**
- Disassociation is a means for either party to terminate an association and can happen because of completion of activity, overloading, or some other reason.
- The requesting device ceases the association and begins again the process of associating; meanwhile, **the malicious outsider has changed the MAC address to that of the disassociated device and continues the association with the access point as if it were the original user**

The attack is possible because frames lack integrity protection (**not in WPA2**)



Attacks on WPA: Incomplete Authentication

- At one point, the supplicant (client) is required to authenticate to the access point, but the supplicant has no basis for assurance that the access point is legitimate, that is, that a malicious party is not sending signals pretending to be an access point.
- Thus, the supplicant can be forced to reveal authentication data to an unauthorized third party.



Attacks on WPA: Exhaustive Key Search

- WPA uses a 256-bit base key, which seems long enough to be secure
- Very long passphrase entered in the access point and device
 - User chose popular passphrases
 - PRO – the WPA algorithm to convert passphrases into numerical key is slow, that reduce the the ability of an attacker to test a large number of potential passphrases as keys
- chopchop - Attack to the integrity do discover key
 - chop out and replace one byte of a block and see the change in the block's integrity – repeating this process allow to infer the integrity key
 - Not effective in WPA2



WPA3 (2018)

- The basic structure of WPA remains the same
- Precludes dictionary attacks against passwords,
- Uses longer encryption keys and stronger encryption algorithms
- Supports an easy-to-use association technique that avoids passwords



Denial of Service



Denial-of-Service (DoS)

- An attempt to defeat availability
- Not binary
 - denial of service ranges from complete loss of access to noticeable and unacceptable slowing to minor inconvenience
- Causes
 - **volume-based** or **volumetric** attacks – exceed the capacity of the system (e.g. network)
 - **application-based** attack -- an attack can exhaust the application
 - cut or disable the communications link between two points
 - hardware or software failure



DoS - three root threats to availability

Flooding (insufficient capacity) -- The target of a flooding attack can be

- an application, such as a database management system;
- an operating system or one of its components, for example, file or print server;
- a network appliance like a router.
- a resource, such as a memory allocation table or a webpage

Blocked Access -- prevent a service from functioning by

- exploiting a software vulnerability in an application and cause the application to crash
- interfering with the network routing mechanisms, preventing access requests from getting to the server
- manipulating access control data, deleting access permissions for the resource, or to disable the access control mechanism so that nobody could be approved for access
- Encrypting data!!!

Access Failures – unresponsive components because an HW/SW failure

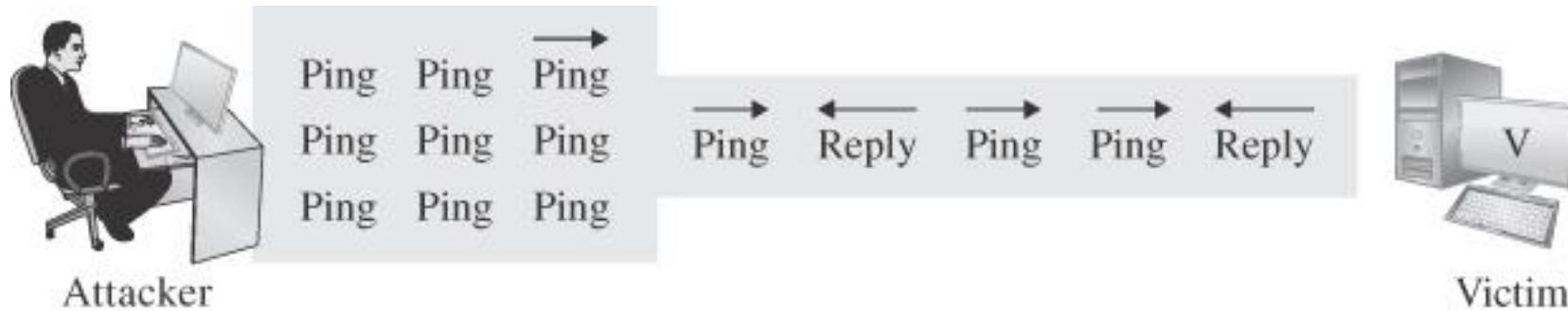


Network flooding

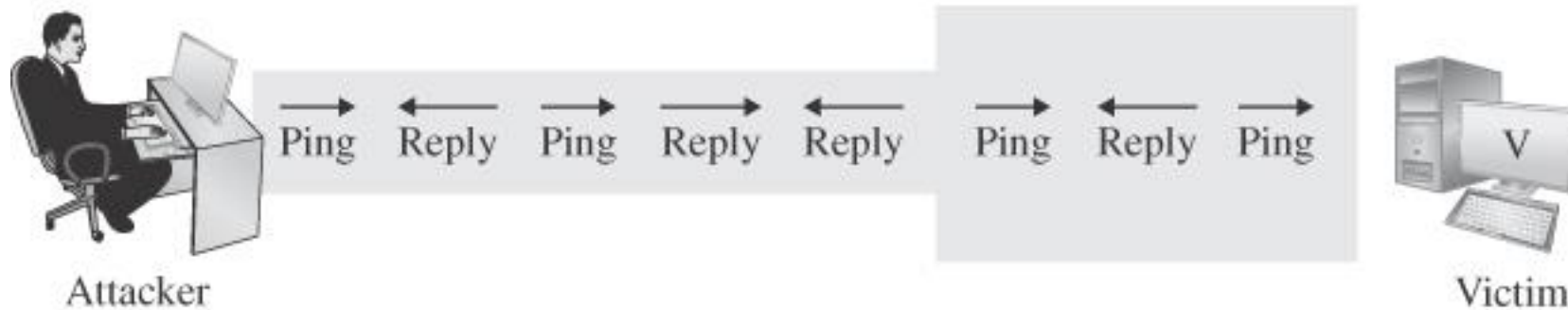
- TCP, UDP or ICMP
 - Ping-of-death
 - Smurf
 - Echo-chargen
 - SYN-flood



Ping of death



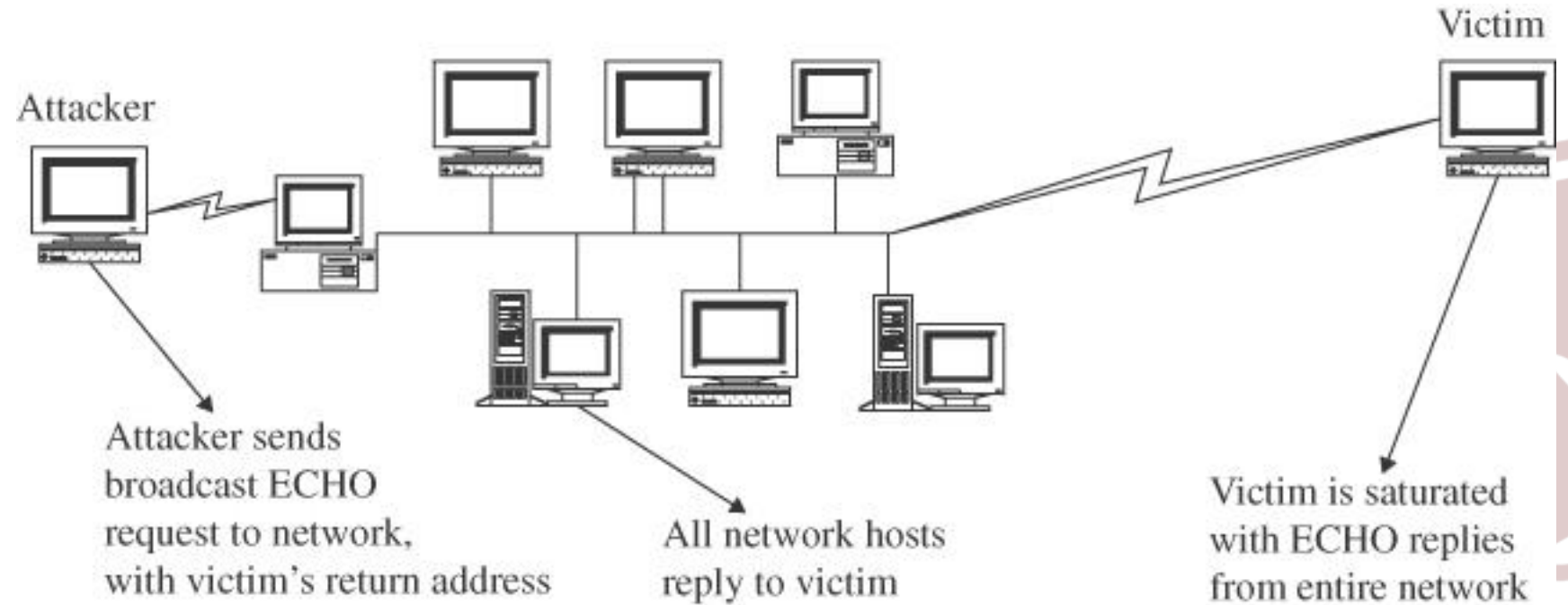
(a) Attacker has greater bandwidth



(b) Victim has greater bandwidth

casali@di.uniroma1.it

Smurf



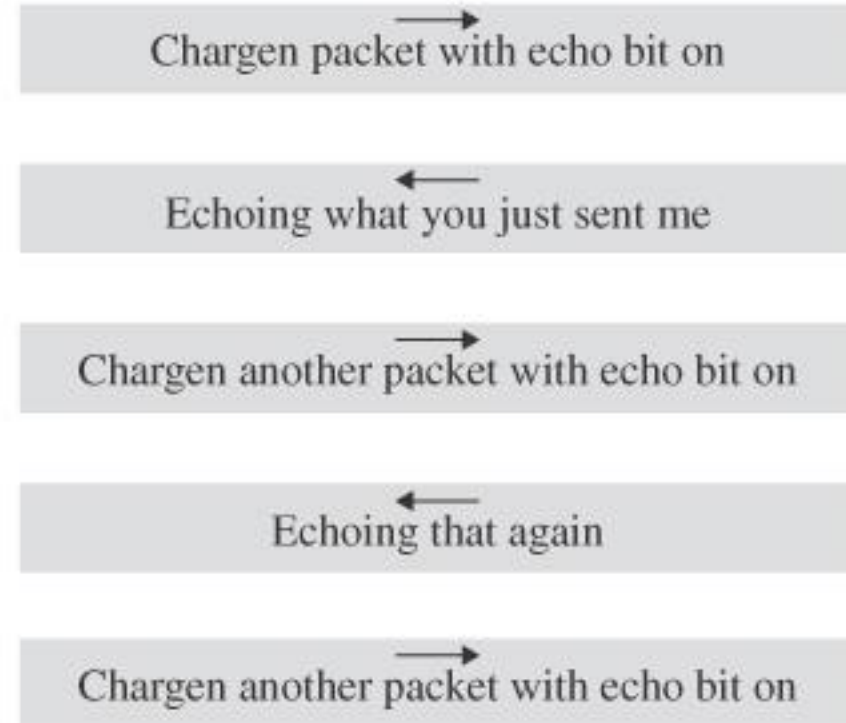
Leverage broadcast mechanism of a network

1. the attacker chooses a network of unwitting victims that become accomplices
2. The attacker spoofs the source address in the ping packet so that it appears to come from the victim, which means a recipient will respond to the victim
3. Then the attacker sends this request to the network in broadcast mode by setting the last byte of the address to all 1s;

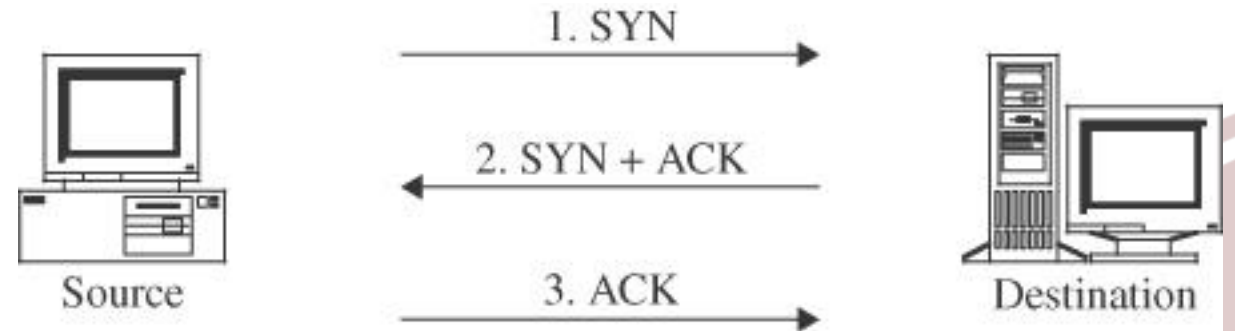
Echo-chargen



- Leverage echo packets
 - this series puts the network infrastructures of A and B into an endless loop
 - Alternatively, the attacker can make B both the source and destination address of the first packet, so B hangs in a loop, constantly creating and replying to its own messages.



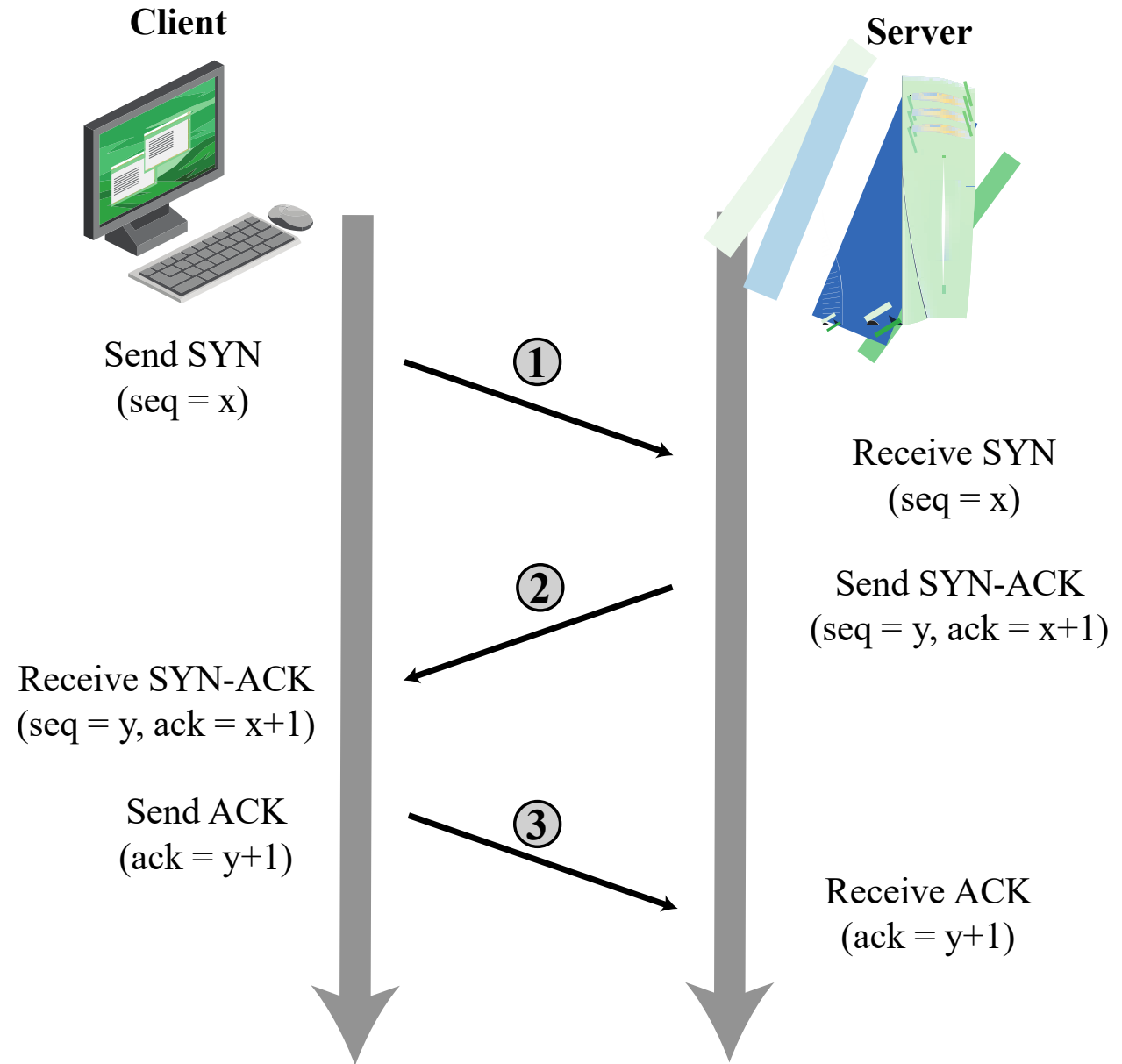
SYN-flood



- If 3 is not sent, the SYN_RECV connections queue get full preventing access to legitimate SYN messages
- Usually, the attacker spoof a nonexistent return address in the initial SYN packet
 - To hide the attacker identity
 - To make legitimate the malicious packets (a different spoofed address for each packet)

SYN Spoofing attack

The TCP three-way handshake

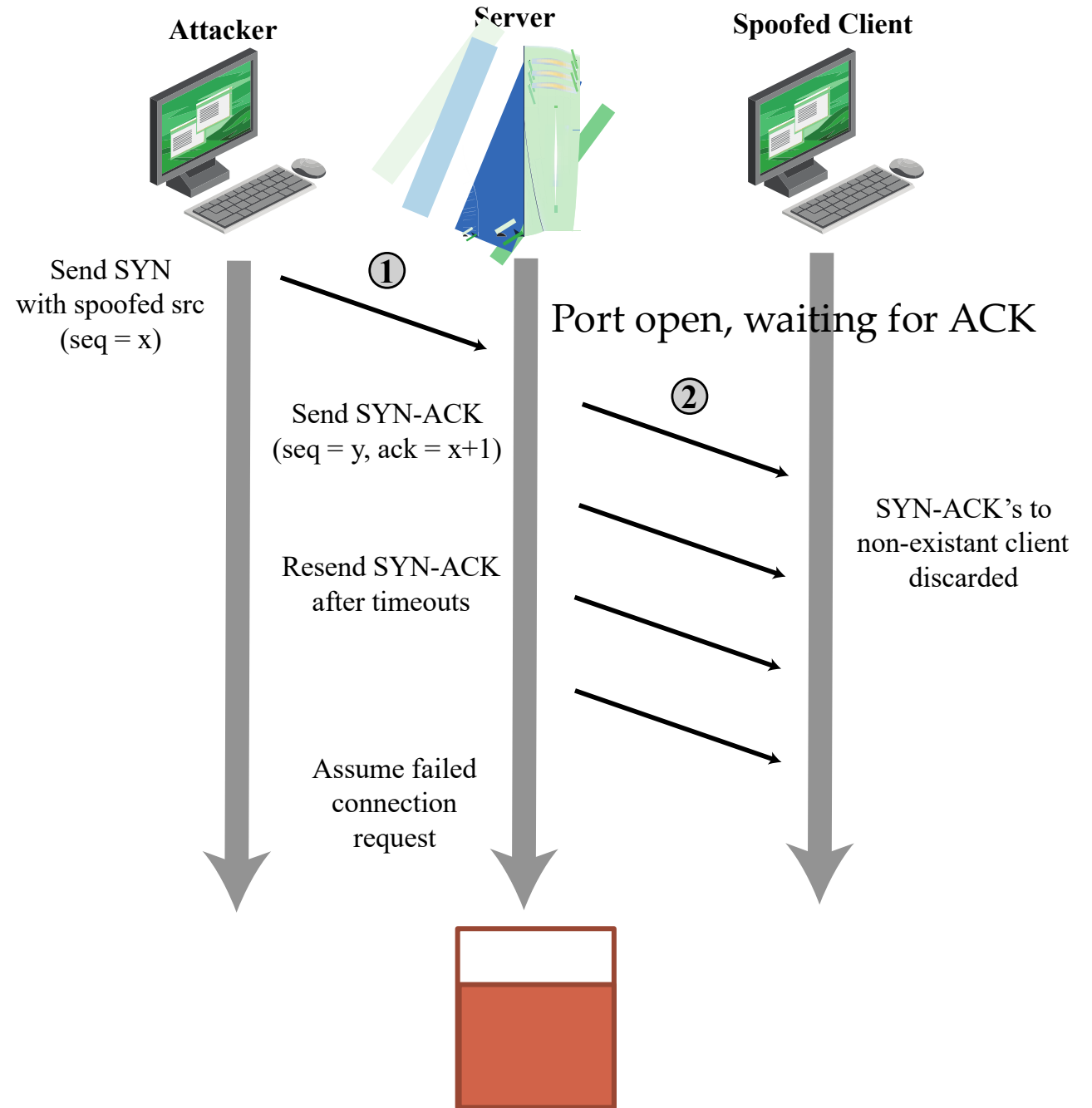




emc — netstat -a — 80x24

tcp4	0	0	10.10.82.18.53771	40.79.141.153.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53769	mil07s19-in-f1.1.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53767	52.123.128.14.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53766	52.123.128.14.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53765	52.123.144.123.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53764	52.112.100.52.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53763	52.123.137.5.https	ESTABLISHED
tcp4	77	0	10.10.82.18.53760	ec2-44-197-151-2.https	CLOSE_WAIT
tcp4	0	0	10.10.82.18.53759	216.239.36.223.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53758	216.239.36.223.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53756	server-13-226-24.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53754	52.97.168.194.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53753	lb-140-82-114-25.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53749	mil04s43-in-f10..https	ESTABLISHED
tcp4	0	0	10.10.82.18.53748	ec2-13-216-108-5.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53734	par21s06-in-f234.https	CLOSE_WAIT
tcp4	0	0	10.10.82.18.53733	waw02s05-in-f10..https	CLOSE_WAIT
tcp4	0	0	10.10.82.18.53730	par21s06-in-f229.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53726	ec2-23-23-139-18.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53722	52.123.255.226.https	ESTABLISHED
tcp4	0	0	10.10.82.18.53716	waw02s05-in-f10..https	ESTABLISHED
tcp4	0	0	10.10.82.18.53398	52.123.200.45.https	ESTABLISHED
tcp6	0	0	fe80::aede:48ff:.53000	fe80::aede:48ff:.49170	ESTABLISHED
tcp6	0	0	fe80::aede:48ff:.52860	fe80::aede:48ff:.49169	ESTABLISHED

SYN Spoofing attack



IP Fragmentation: Teardrop attack

- the datagram protocol permits a single data unit to be fragmented, that is, broken into pieces and transmitted separately.
- Each fragment indicates its length and relative position within the data unit. The receiving end reassembles the fragments into a single data unit
- In the teardrop attack, **the attacker sends a series of datagrams that cannot fit together properly**
- **The operating system locks up** with these partial data units it cannot reassemble, thus leading to denial of service

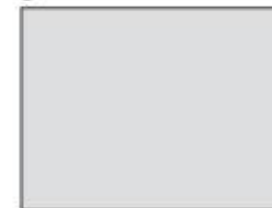
Fragment start = 10 len = 50



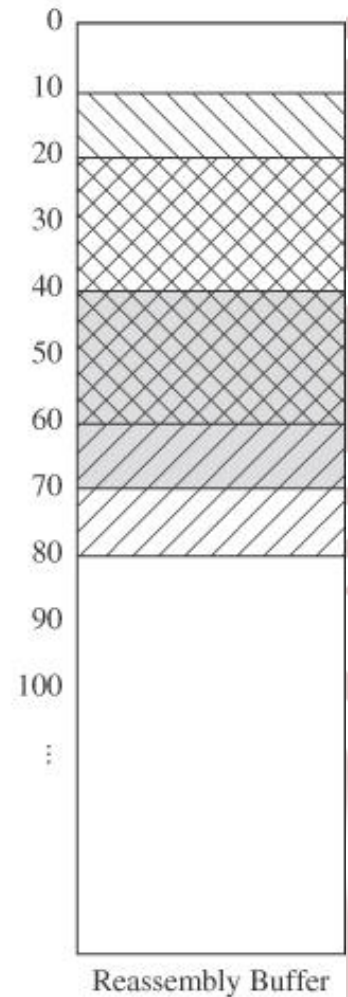
Fragment start = 20 len = 60



Fragment start = 40 len = 30



Packet Fragments



DNS Poisoning

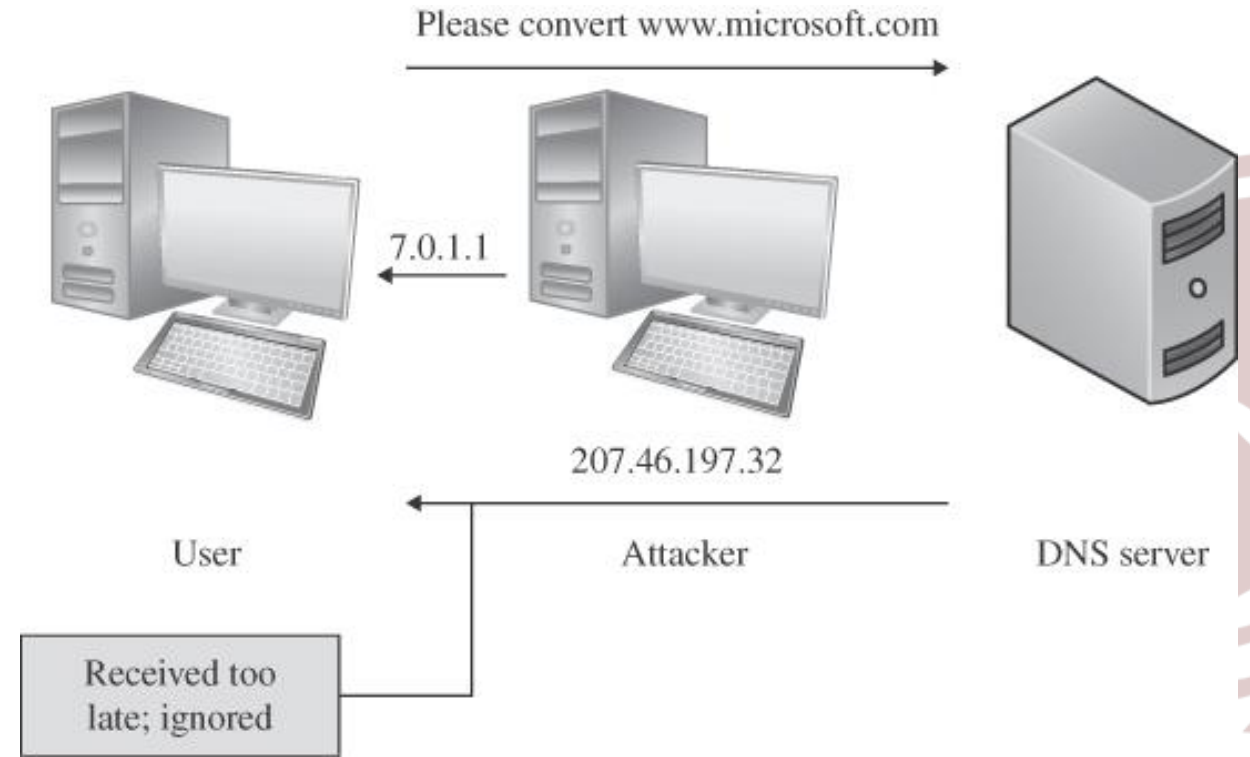
- DNS server builds a cache of recently used domain names
- With an attack called DNS poisoning, attackers try to insert inaccurate entries into that cache so that future requests are redirected to an address the attacker has chosen and/or denying access to a legitimate site



- DNS queries remain open until answered and that a response matching the ID number for the query will be cached
- If an attacker can guess the sequence of query ID numbers, the attacker can forge a response that satisfies an open query's ID; that forged reply can provide any address as a response
- Until the response is removed from the cache, all traffic for the requested address will be directed to the address given in the forged reply

DNS Spoofing

- A MiM attack
- To redirect a user to another address denying access to the target one



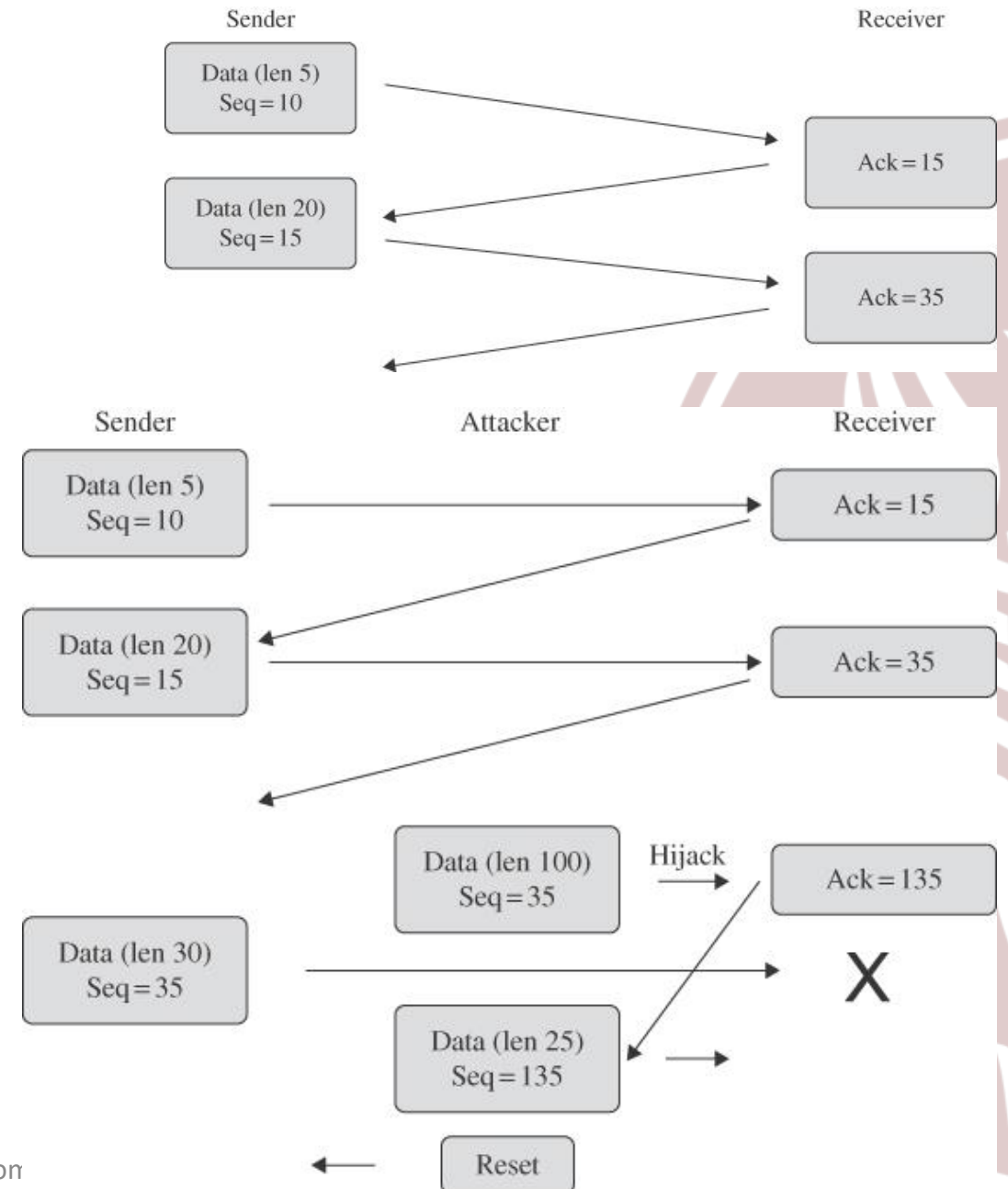
Top-Level Domain Attacks

- These attacks attempt to deny service by limiting the system's ability to resolve addresses.
- Because address resolution is distributed in the internet, these attacks tend to be more effective at causing localized denial of service and less effective against large segments.



Session Hijack

- In a **session hijack** attack, the attacker allows an interchange to begin between two parties but then diverts the communication
- In normal TPC sequence
 - If the client sends a packet with an erroneous pair of sequence and acknowledgement numbers, this disrupts synchronization, and the receiver discards packets until receiving one that matches the previous acknowledgment number.
 - If they do not resynchronize, they terminate and reestablish the session
- The attacker can take advantage of this correction by inserting a packet that maintains synchronization with the receiver but destroys synchronization with the real sender.



Routing attacks

Poisoning routing table makes possible to reroute the traffic toward a specific router

- Routers implicitly trust each other
- Each router advertise the networks it can reach and in how many hops (and other QoS metrics); This advertisement is propagated
- A router R can advertise it can reach every destination in just one hop or in the best way – that make possible two attacks

→ **MiM attack**: R will receive all the traffic and can act as MiM

→ **DoS attack**: R will be flooded by requests

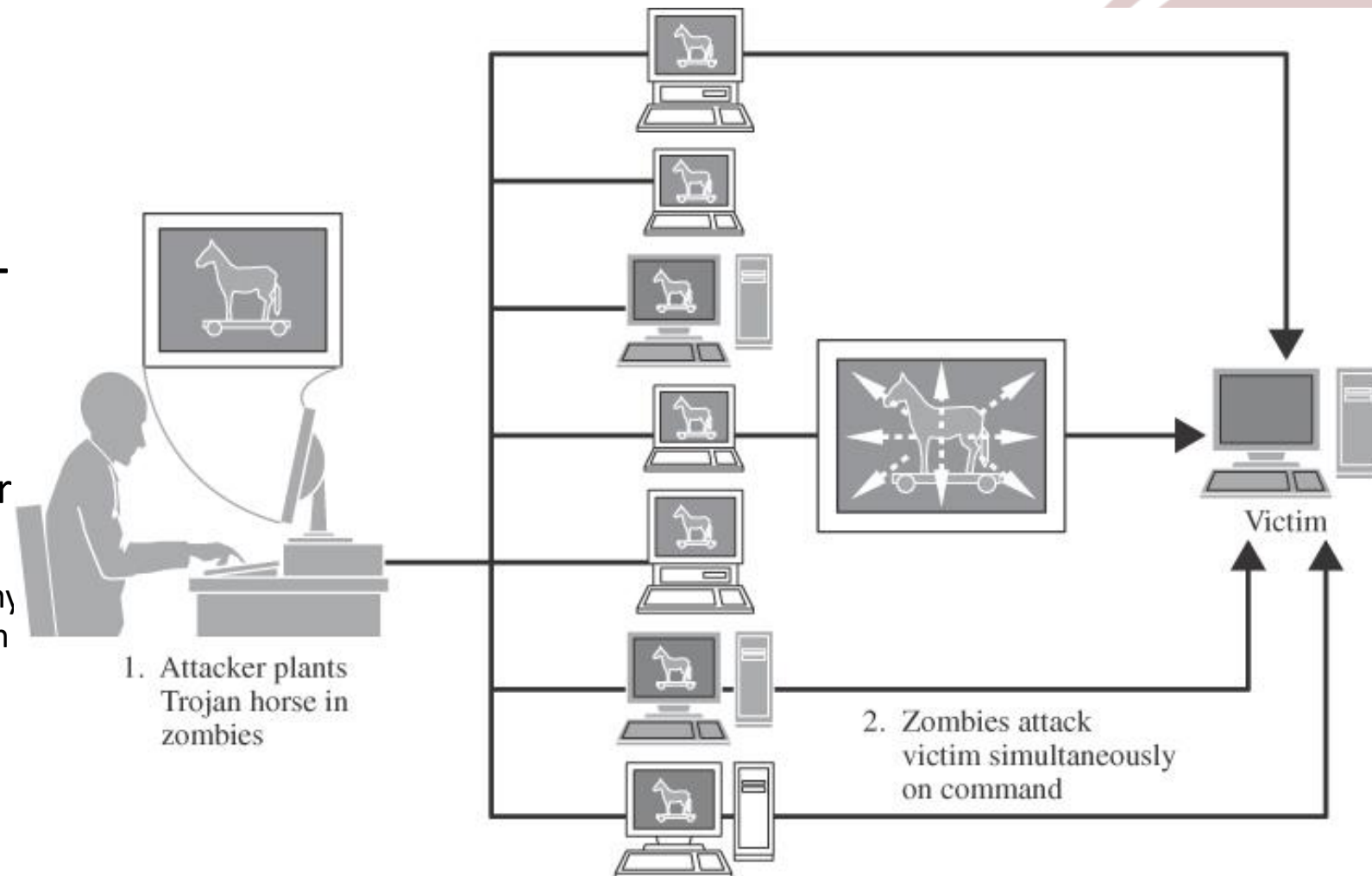
Source routing (strict or loose)

- Allow to specify the specific path a packet should follow
- If used in a malicious way, allow to force data to flow through a malicious router or network link
→ **MiM;DoS**



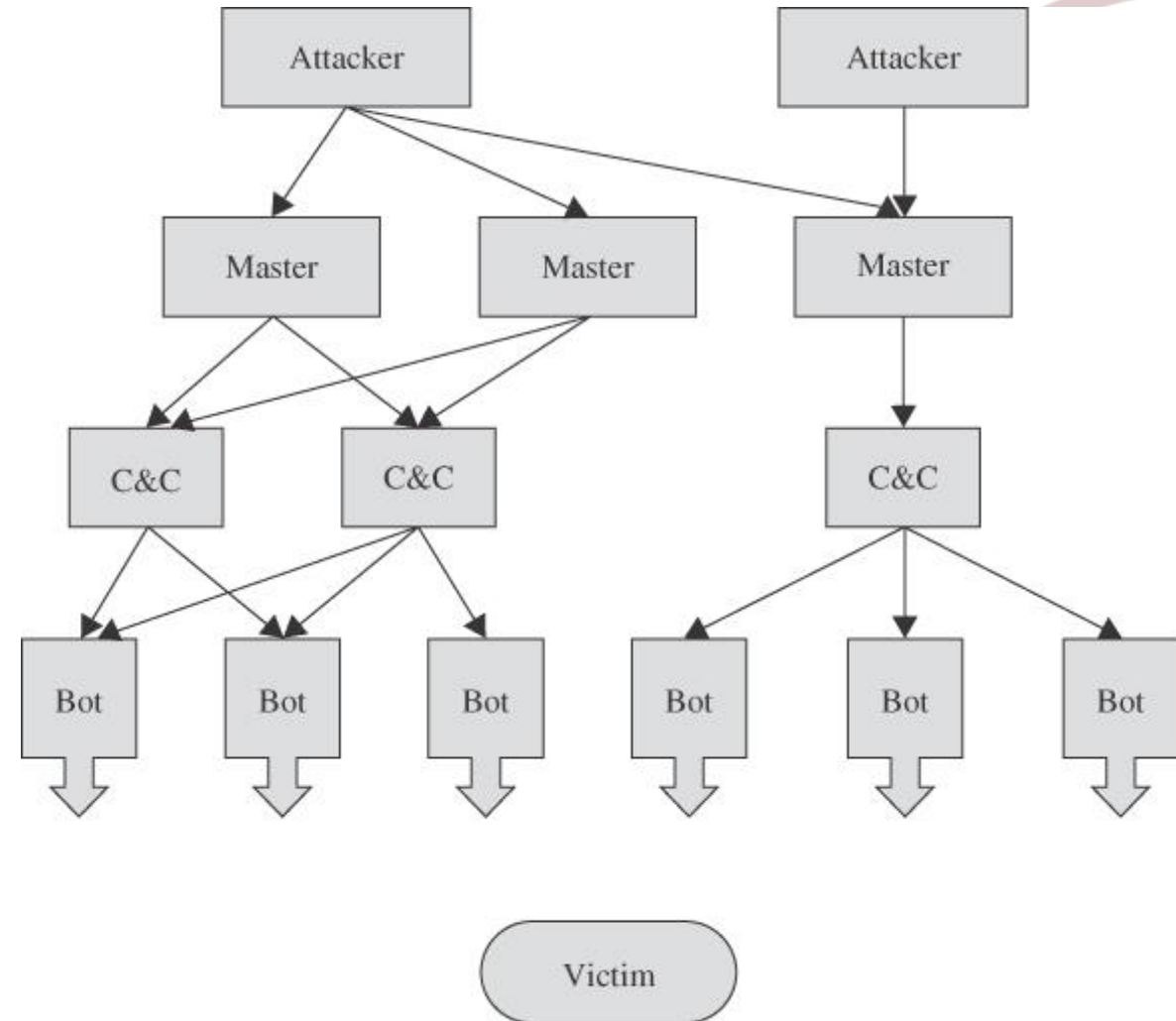
Distributed Denial of Service

- Distributed denial-of-service attacks change the balance between adversary and victim by marshalling many forces on the attack side
- To mount a **distributed denial-of-service** (or **DDoS**) attack, an attacker does two things (1,2)
- That Trojan horse does not necessarily cause any obvious harm to the infected machine
 - the machine needs to remain healthy (and infected) so it can participate in the attack against the real victim



Botnet

- Bots are “recruited” by scanning internet hosts for vulnerabilities
 - malicious autonomous mobile agents
 - propagation methods
- Implanted Trojan horse can implement different DoS technique to be selected at attack time (one or more)
 - Inoculation agent to modify/update techniques
- Bots organized in a network (C&C)
 - Attacker isolated to avoid detection
 - Master and C&C redundant to be capable of operate also if a portion of the botnet is taken down
 - Bots receive commands and updates in push or pull mode



Response to DoD/DDoS

- Autonomous Mobile Protective Agents
 - A modified Trojan horse – that looks like a malicious one - to spread a counterinfection, e.g., an update that disable the malicious Trojan Horse
- Continuously patching vulnerabilities!!!
- techniques such as
 - tuning (adjusting the number of active servers)
 - load balancing (evening the computing load across available servers)
 - shunning (reducing service given to traffic from certain address ranges)
 - blacklisting (rejecting connections from certain addresses)



Countermeasures

Cryptography

Firewalls

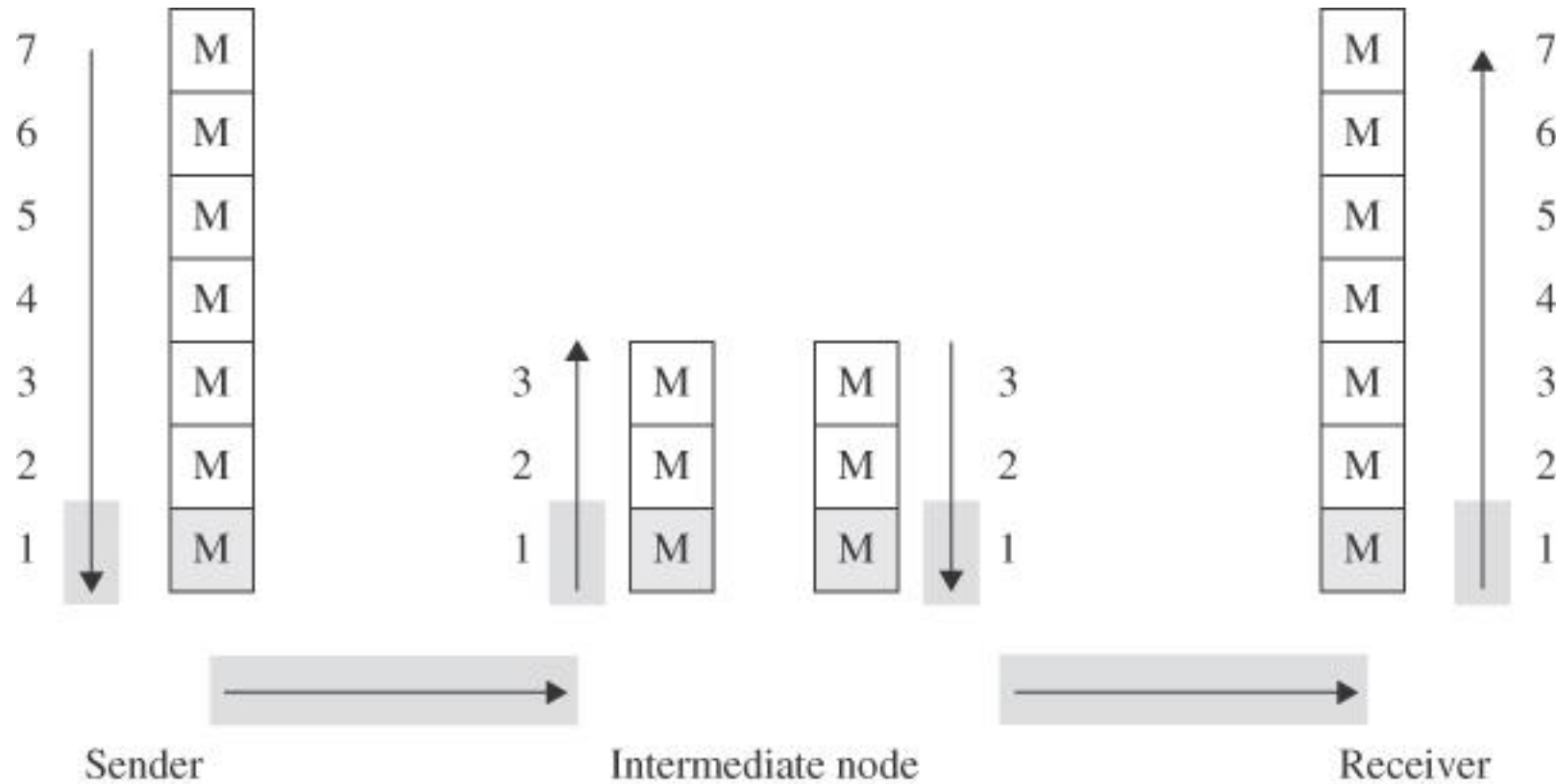
Intrusion Detection & Response



Network Criptography



Link Encryption



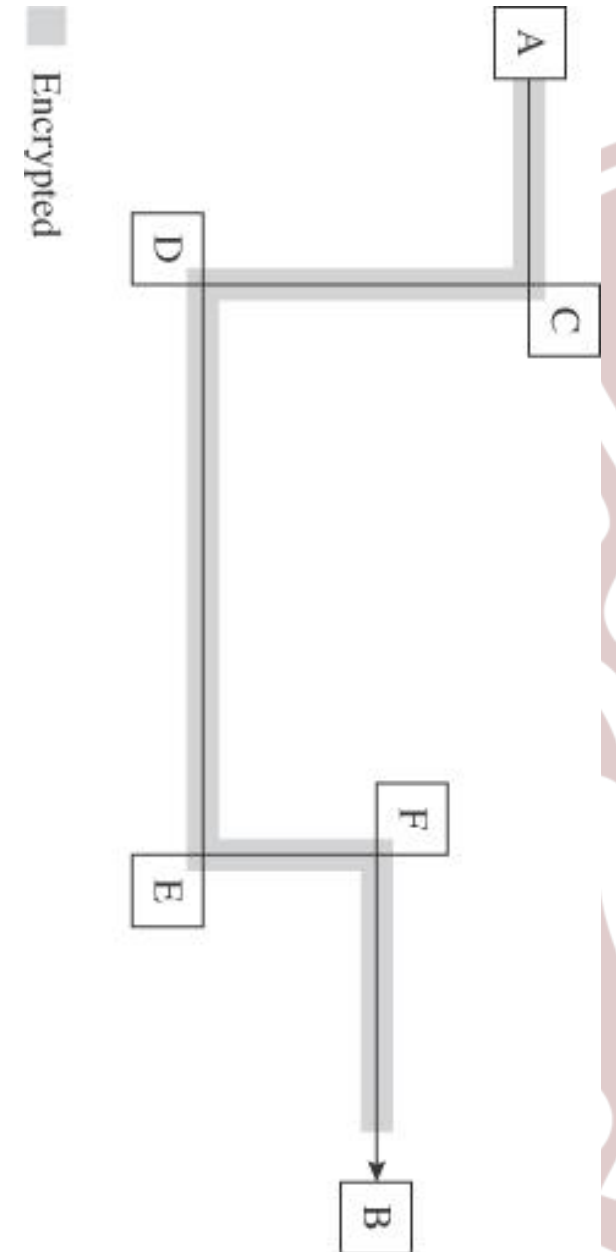
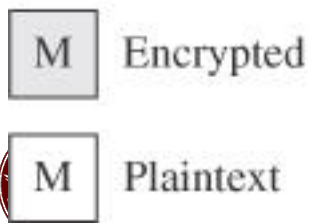
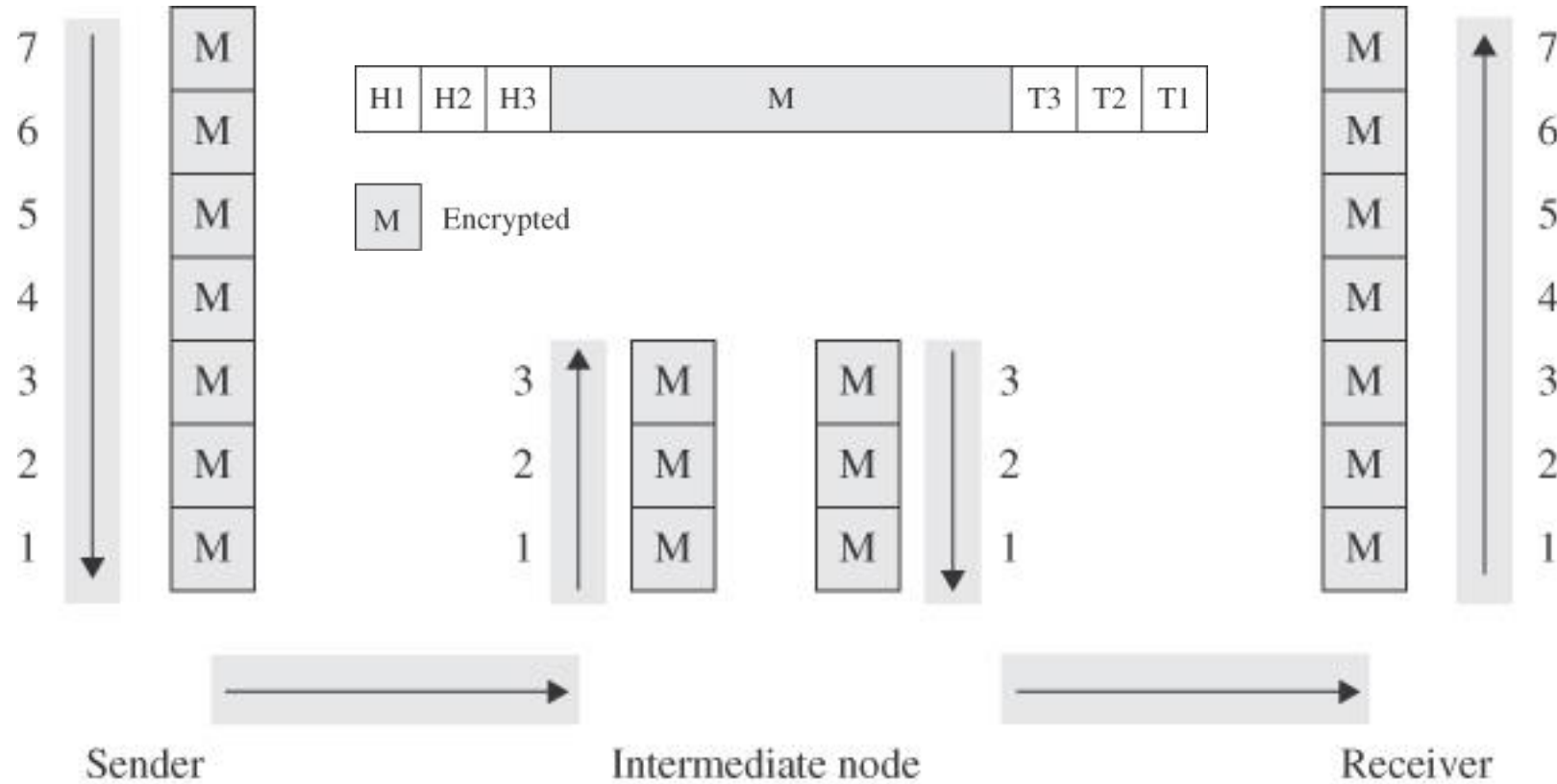
 Encrypted

 Plaintext



 Encrypted

End-to-End encryption



	Link Encryption	End-to-End Encryption
Security within hosts	Data partially exposed in sending host Data partially exposed in intermediate nodes	Data protected in sending host Data protected through intermediate nodes
Role of user	Applied by sending host Invisible to user Host administrators select encryption Key managed centrally by host administrator Can be done in software or hardware All or no data encrypted	Applied by user application User application encrypts User selects algorithm Each user (or user's application) manages key individually Usually software implementation; occasionally performed by user add-on hardware User can selectively encrypt individual data items
Implementation considerations	Requires one key per pair of hosts Provides node authentication	Requires one key per pair of users Provides user authentication

SSH Encryption

- Secure Shell (SSH) provides an authenticated and encrypted path to the shell or operating system command interpreter
- The SSH protocol involves negotiation between local and remote sites for
 - encryption algorithm (for example, DES or AES)
 - authentication (including public key and Kerberos)



SSL and TLS Encryption

- SSL1.0 → SSL2.0 → SSL3.0 (renamed TLS)
- An **encryption protocol** to protect data being transmitted across the internet
 - The primary use of SSL is to protect data confidentiality
- It can use a variety of commercial encryption algorithms and a certificate structure for authentication and key exchange
- Implemented at level 4 (OSI)
 - operates between applications (such as browsers) and the TCP/IP protocols
 - Client and server negotiate encryption algorithms, called the **cipher suite**, for authentication, session encryption, and hashing
- SSL/TLS+HTTP → HTTPS



Cipher Suites

CCM and GCM are different ways to link blocks of ciphertext

Cipher Suite Identifier	Algorithms Used
TLS_AES_256_GCM_SHA384	AES with a 256-bit key encryption, 384-bit SHA hash function
TLS_CHACHA20_POLY1305_SHA256	Chacha20–Poly1305 stream cipher, 256-bit SHA hash function
TLS_AES_128_GCM_SHA256	AES with a 128-bit key encryption, 256-bit SHA hash function
TLS_AES_128_CCM_8_SHA256	AES with a 128-bit key encryption, 256-bit SHA hash function
TLS_AES_128_CCM_SHA256	AES with a 128-bit key, SHA-1 hash function



IPsec

Designed to address spoofing, eavesdropping, and session hijacking

- defines a standard means for handling encrypted data

Implemented at the IP layer (L3)

- it protects data produced in all layers above it, in particular, TCP and UDP control information, as well as the application data

Security Association -- the set of security parameters for a secured communication channel

- encryption algorithm and mode (for example, AES)
- encryption key
- encryption parameters, such as the initialization vector
- authentication protocol and key
- life span of the association, to permit long-running sessions to select a new cryptographic key as often as needed
- address of the opposite end of the association
- sensitivity level of protected data (usable for classified data)

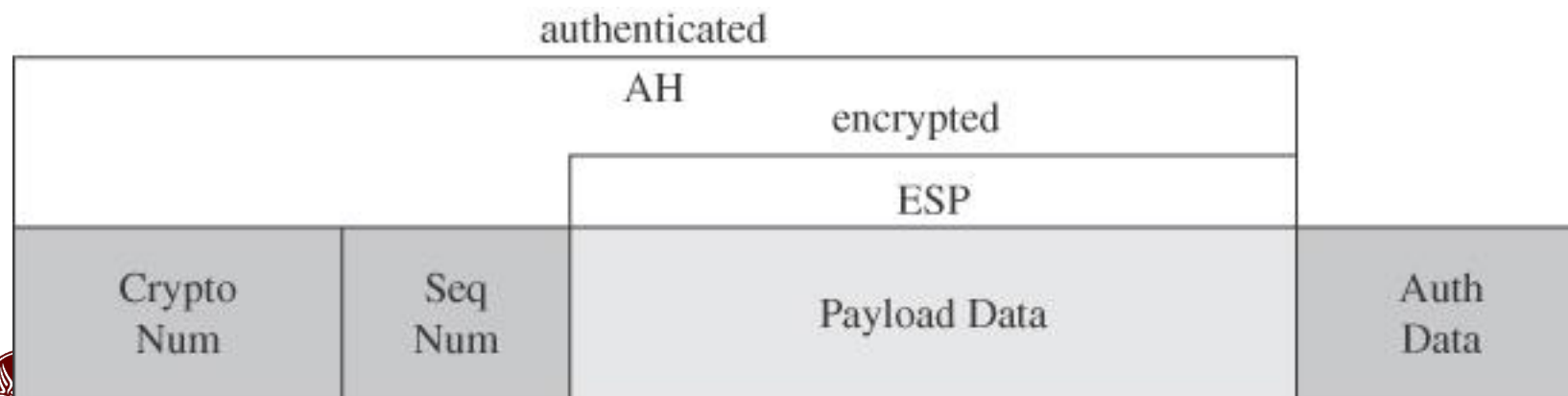


IPSec header and data

No encryption



IPSec



- Crypto Num
 - Info on the cypher suite used
- Seq Num
 - To prevent replay attack
- Auth Data
 - For authentication management

IPSec Key Management

- The critical element is key management
- IPsec addresses this need with the **Internet Security Association Key Management Protocol (ISAKMP)**
- In IPsec, ISAKMP is implemented through the **ISAKMP key exchange (IKE)** which provides a way to manage and agree on protocols, algorithms, and keys.
- IKE uses the Diffie–Hellman scheme to generate a mutually shared secret that will then be used as an encryption key
 - With their shared secret, the two parties exchange identities and certificates to authenticate those identities.
 - Finally, they derive a shared cryptographic key and enter a security association

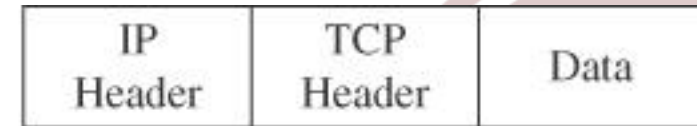


IPSec Mode of Operation

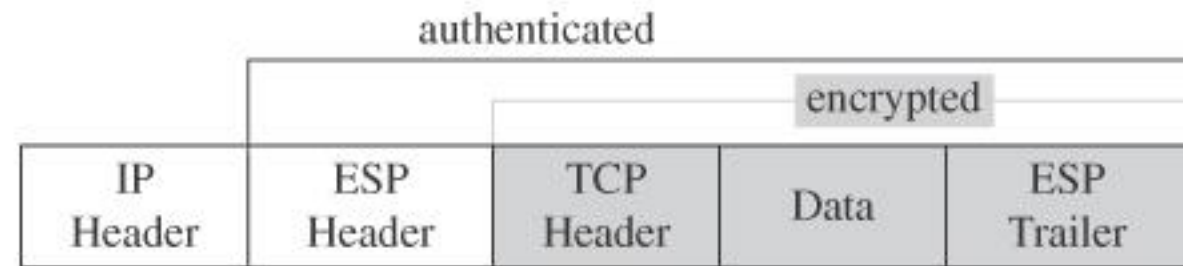
Transport mode (normal operation), the IP address header is unencrypted.

Tunnel mode, the recipient's address is concealed by encryption

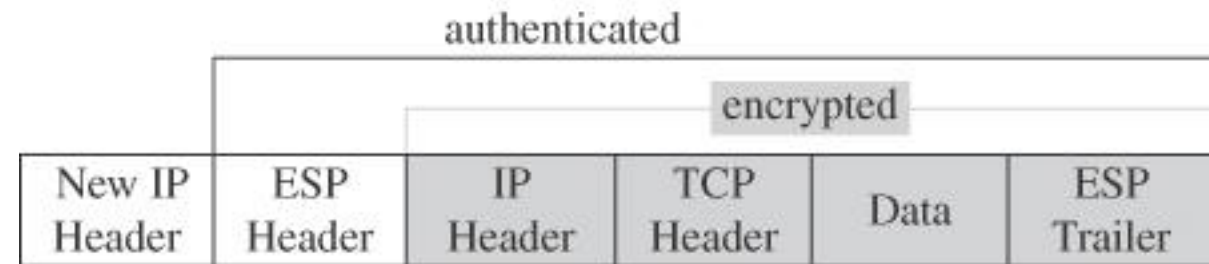
- IPsec substitutes the address of a remote device, such as a firewall or router, that will receive the transmission and remove the IPsec encryption.



(a) Original Packet



(b) Transport Mode

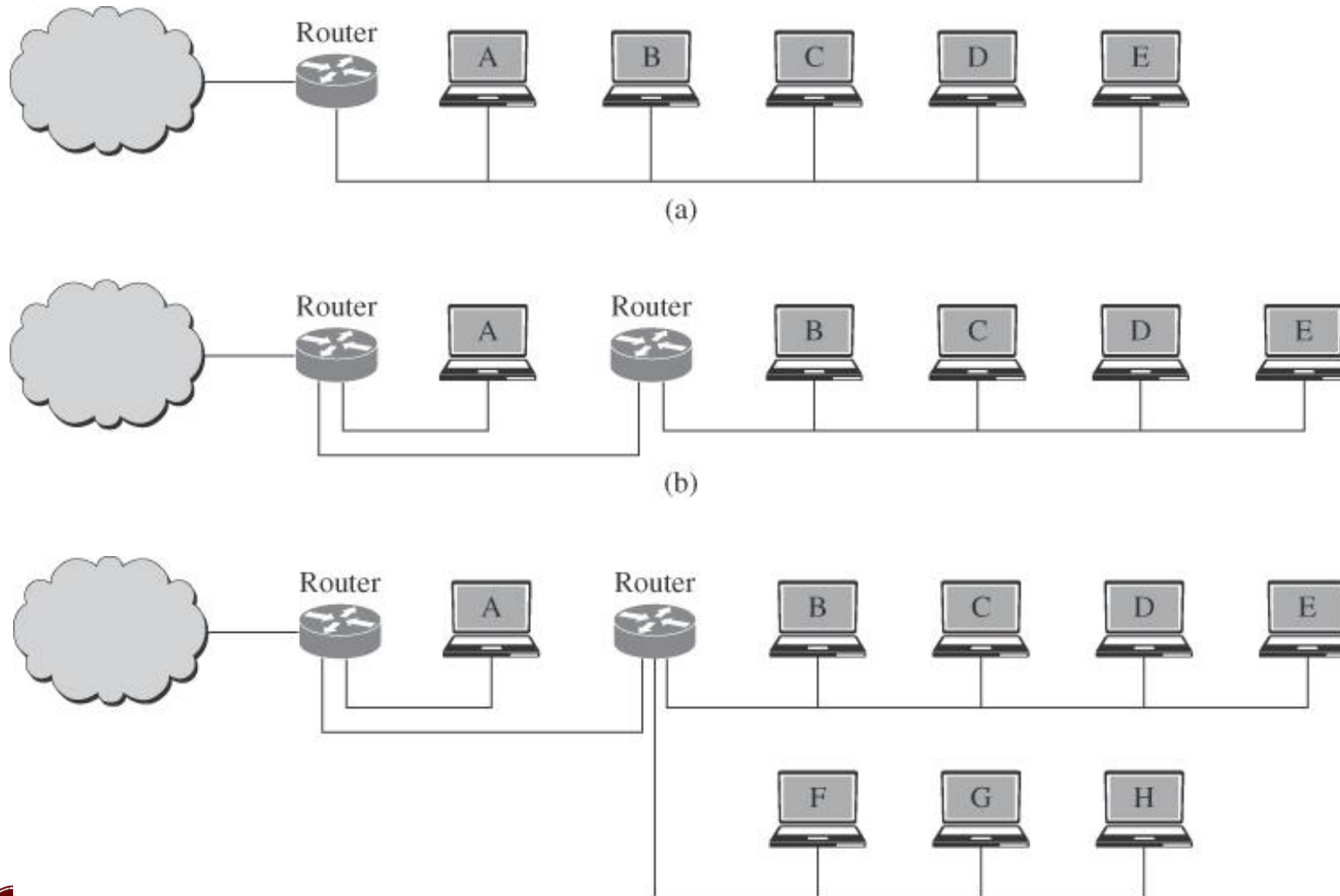


(c) Tunnel Mode

Firewalls



Segmentation to limit host exposure



- (a) all host are visible, vulnerabilities can propagate
- (b) B-E protected subnetwork; A is a **dual-homed gateway**
- With segmentation each subnetwork is vulnerable, but a security failure in one does not necessarily permit compromise of another

- With segmentation we limits or controls data movement, but it does not fully address the central security goal of controlled access
- We need a Firewall



Firewall

A device that runs code to filter all traffic between a protected or “inside” network and a less trustworthy or “outside” network.

- Usually, a firewall runs on a dedicated device;
- it is a single point through which traffic is channeled →, performance is important → only firewall functions should run on the firewall machine

The firewall concept reflect **Reference Monitor** concept

- always invoked
- tamperproof
- small and simple enough for rigorous analysis



Firewall and rules

- Firewalls enforce predetermined rules governing what traffic can flow
 - Administrators update rules to address changing threats or needs
- Two security policy approaches
 - **Default permit**
 - that which is not expressly forbidden is permitted
 - **Default deny**
 - that which is not expressly permitted is forbidden



Firewall design

Two qualities make a Firewall effective:

- a **well-understood traffic flow policy**
- a **trustworthy design** and implementation
- A firewall implements a **security policy**
 - a set of rules that determine what traffic can or cannot pass through the firewall
 - No net definition of what is good and bad traffic → No standard rules



Example of policy

Rules are evaluated from the one with the lower id
(higher priority)

Rule	Type	Source Address	Destination Address	Destination Port	Action
1	TCP	*	192.168.1.*	25	Permit
2	UDP	*	192.168.1.*	69	Permit
3	TCP	192.168.1.*	*	80	Permit
4	TCP	*	192.168.1.18	80	Permit
5	TCP	*	192.168.1.*	*	Deny
6	UDP	*	192.168.1.*	*	Deny



Firewall - Trust

A firewall is an example of the reference monitor

- Always invoked
 - is positioned at a choke point, the single connection between the protected internal network and the potentially hostile outside network
- Tamperproof
 - To be highly immune to modification, a firewall is typically isolated
 - Usually a firewall is implemented on a separate computer, with direct connections only to the outside and inside networks
- Small and simple enough for rigorous analysis
 - Should runs a stripped-down operating system supporting minimal services
 - Should implement only access control
 - Functionalities should be kept simple

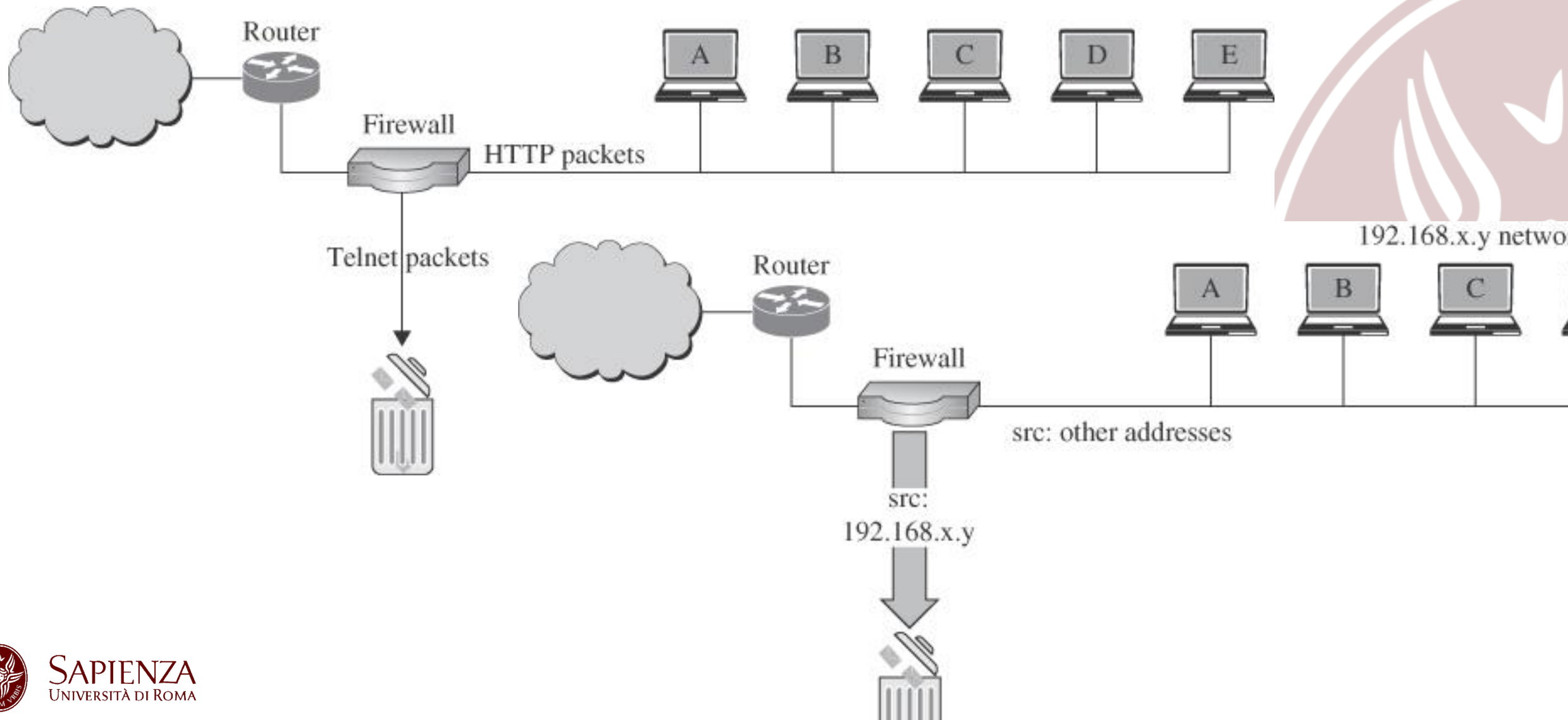


Type of Firewall

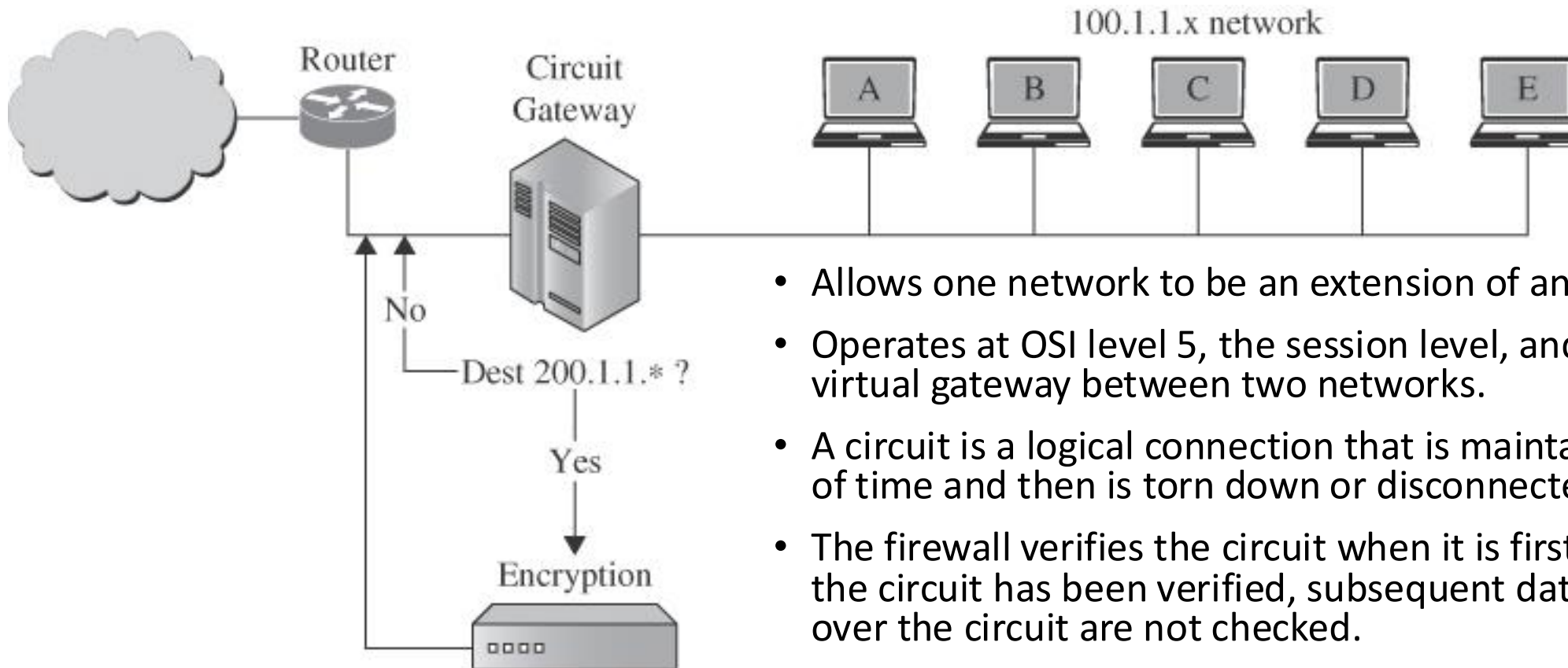
- URL or packet filtering
- circuit-level or traffic and path security
- stateful inspection
- deep packet inspection
- application-level protection, also known as proxying
- guard
- sandboxing
- personal firewalls



URL/Packet filtering (URL filter or packet filtering gateway or screening router)

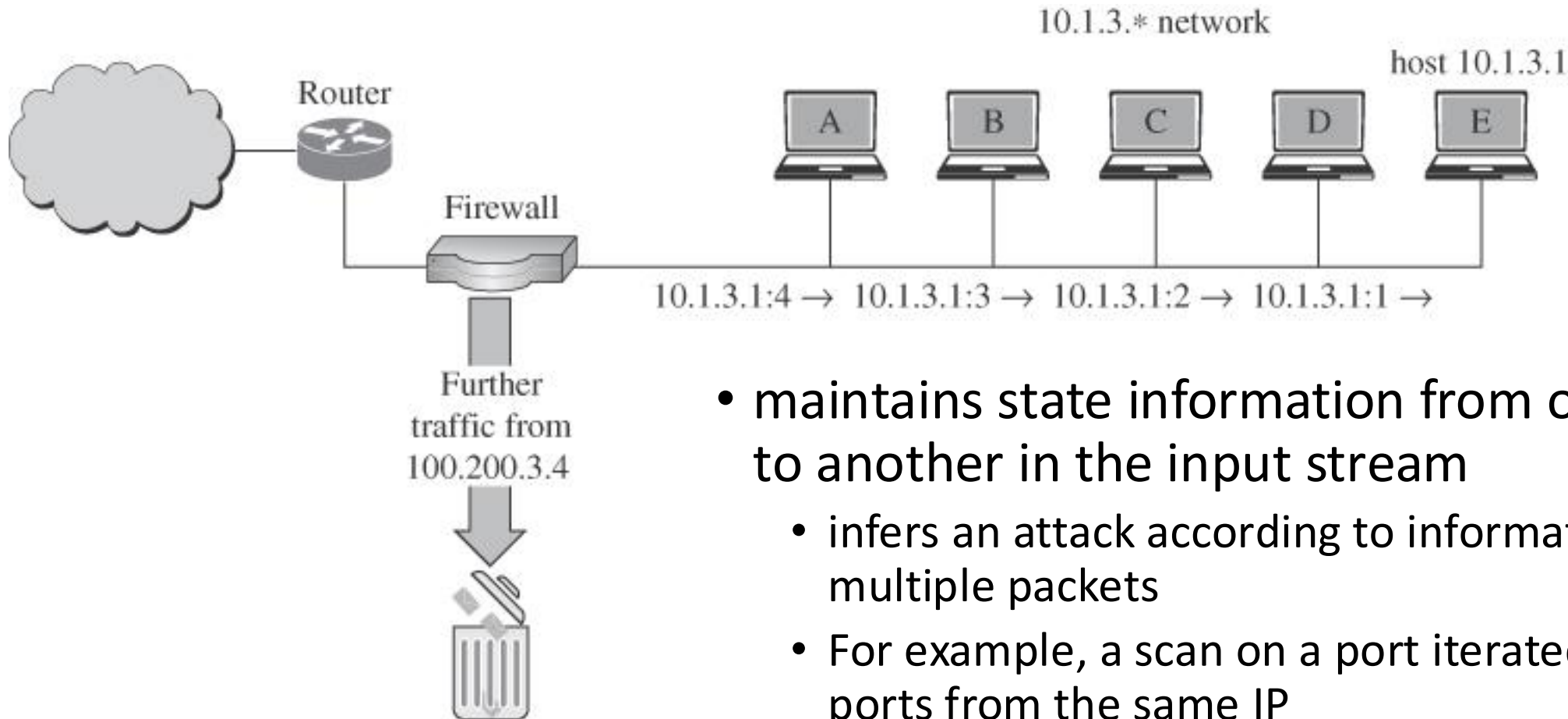


Circuit-Level Gateway



- Allows one network to be an extension of another (e.g. VPN).
- Operates at OSI level 5, the session level, and it functions as a virtual gateway between two networks.
- A circuit is a logical connection that is maintained for a period of time and then is torn down or disconnected.
- The firewall verifies the circuit when it is first created. After the circuit has been verified, subsequent data transferred over the circuit are not checked.
- Circuit-level gateways can limit which connections can be made through the gateway.

Stateful Inspection (or dynamic packet filtering)



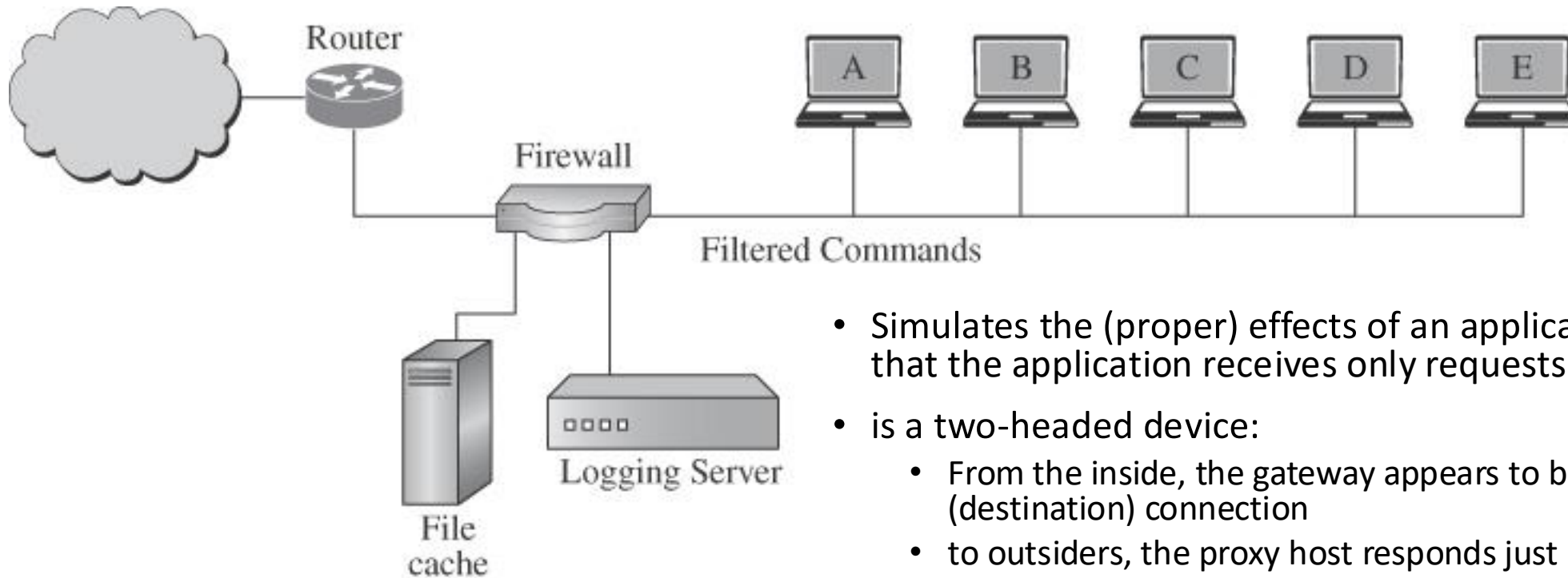
- maintains state information from one packet to another in the input stream
 - infers an attack according to information from multiple packets
 - For example, a scan on a port iterated on many ports from the same IP

Deep Packet Inspection

- accept or reject decision depends on analysis of more than one type of data from a packet
 - Header data
 - Payload content
- Can be used to filter both incoming and outgoing traffic
- Can be used to modify the content of outgoing traffic (e.g. to anonymize content on the fly)



Application Proxy Gateway (or Bastion Host)



- Simulates the (proper) effects of an application at level 7 so that the application receives only requests to act properly
- is a two-headed device:
 - From the inside, the gateway appears to be the outside (destination) connection
 - to outsiders, the proxy host responds just as the insider would
 - Is like a MiM
- Can implement also other functionalities like caching and logging

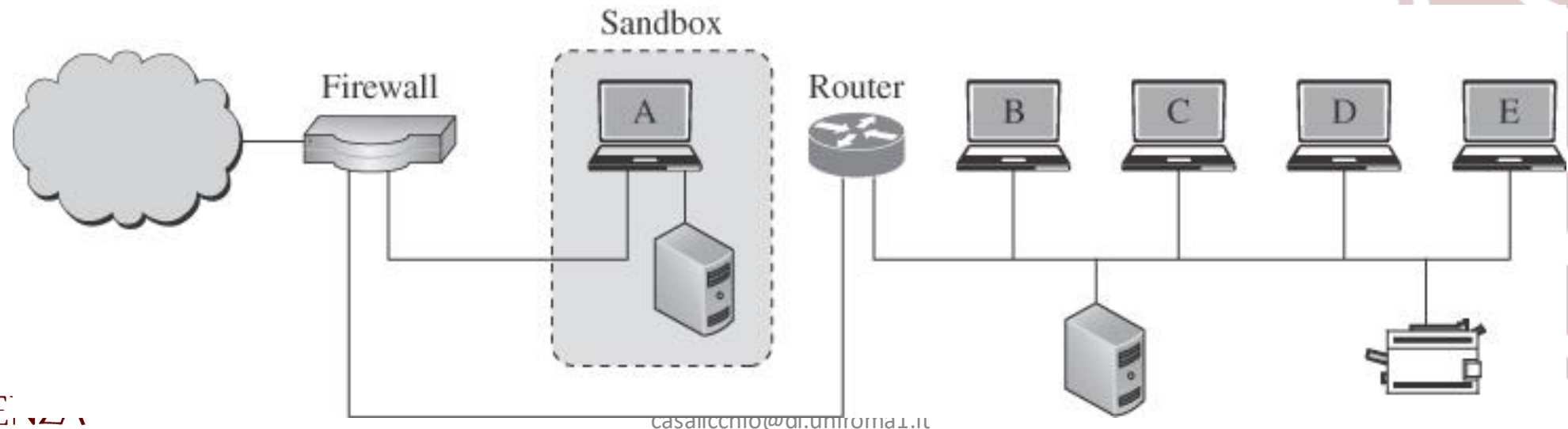
Guard

- A sophisticated firewall
- it receives protocol data units, interprets them, and emits the same or different protocol data units that achieve either the same result or a modified result
- determines what services to perform on the user's behalf in accordance with its available information, such as whatever it can reliably ascertain the (outside) user's identity, previous interactions, and so forth
- The degree of control a guard can provide is limited only by what is computable, e.g.
 - Limit the amount of email messages sent by an user
 - Limit the user's traffic rate
 - Paywall
 - Virus scanner for downloaded content (through FTP or HTTP)



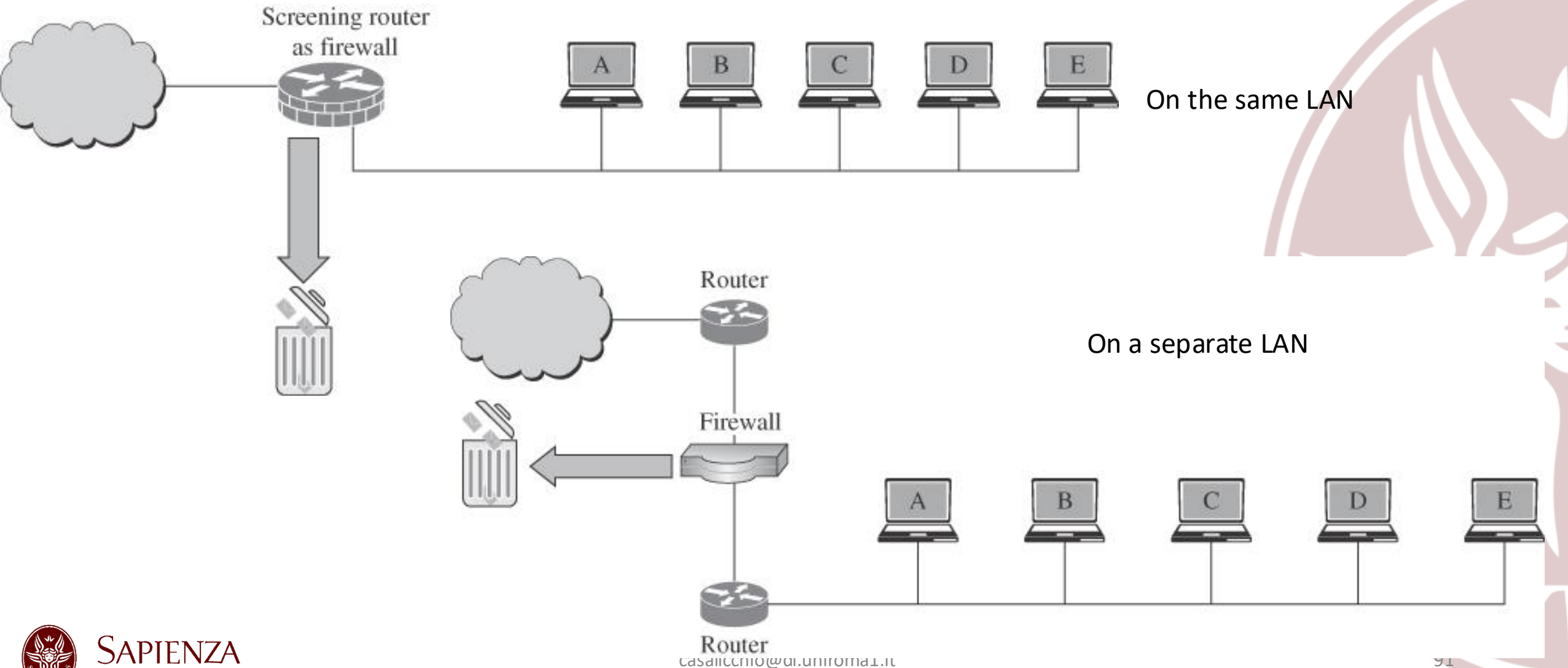
Sandbox

- A firewall can detect inbound code.
- Instead of allowing the code to execute on an internal host, where malicious code could affect sensitive resources or modify or obtain protected data, the code runs in a web-based sandbox, by which its access to resources or data is severely constrained.
- If the code's actions seem benign, a security administrator can decide to permit the code into the protected zone.

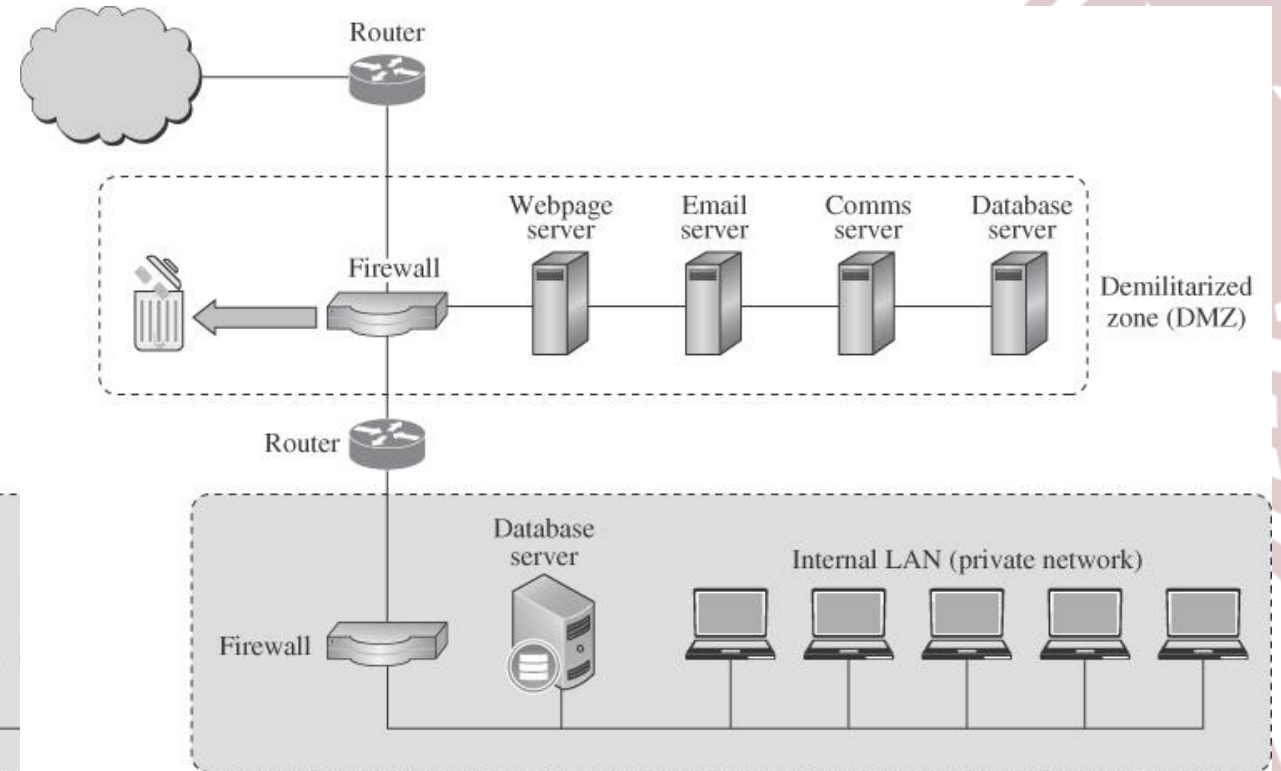
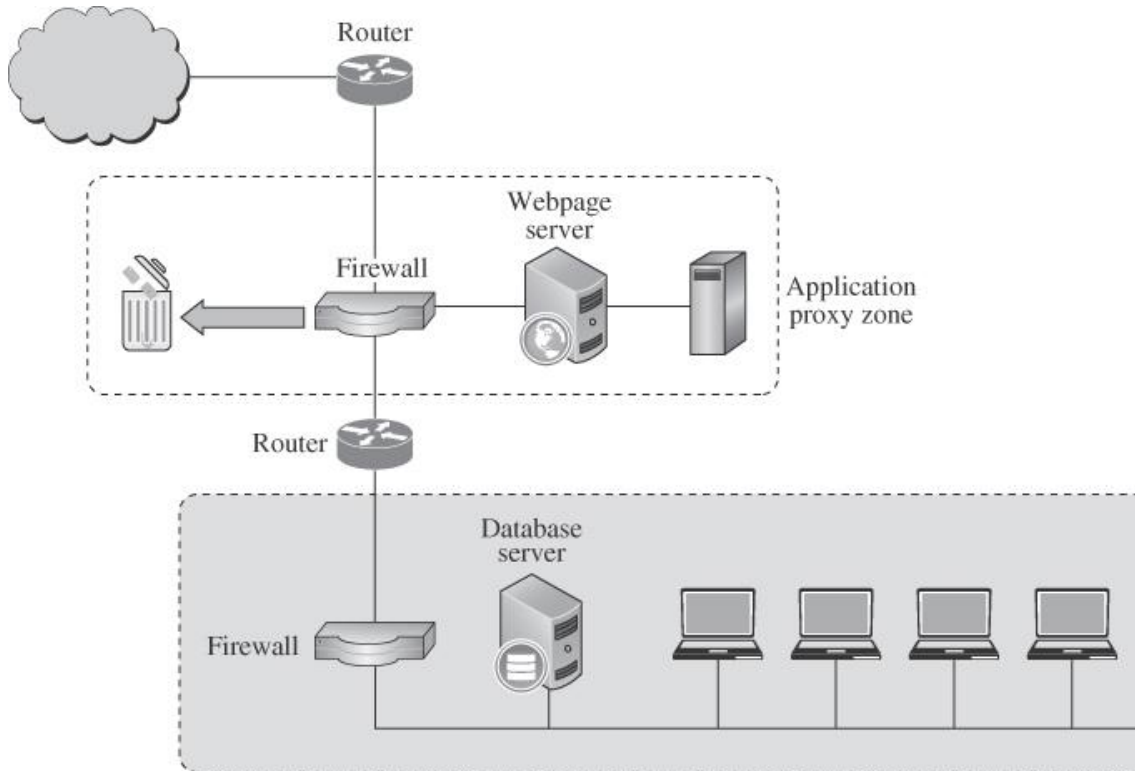


Packet/URL Filter	Circuit Gateway	Stateful Inspection	Application Proxy	Guard	Personal Firewall
Simplest decision-making rules, packet by packet	Joins two subnetworks	Correlates data across packets	Simulates effect of an application program	Implements any conditions that can be programmed	Similar to packet filter, but getting more complex
Sees only addresses and service protocol type	Sees addresses and data	Can see addresses and data	Sees and analyzes full data portion of pack	Sees and analyzes full content of data	Can see full data portion
Auditing limited because of speed limitations	Auditing likely	Auditing possible	Auditing likely	Auditing likely	Auditing likely
Screens based on connection rules	Screens based on address	Screens based on information across multiple packets—in either headers or data	Screens based on behavior of application	Screens based on interpretation of content	Typically, screens based on content of each packet individually, based on address or content
Complex addressing rules can make configuration tricky	Relatively simple addressing rules; make configuration straightforward	Usually preconfigured to detect certain attack signatures	Simple proxies can substitute for complex decision rules, but proxies must be aware of application's behavior	Complex guard functionality; can be difficult to define and program accurately	Usually starts in mode to deny all inbound traffic; adds addresses and functions to trust as they arise

Firewall configurations: Same or Separate LAN



Firewall Configuration: Application Proxy, DMZ



Firewall limitations

- Firewalls can protect an environment only if the firewalls control the entire perimeter.
 - are effective only if no unmediated connections breach the perimeter.
 - If even one inside host connects to an outside address without going through the firewall, by a wireless connection for example, the entire inside net is vulnerable through the unprotected host
- Firewalls do not protect data outside the perimeter;
 - data that have properly passed (outbound) through the firewall are just as exposed as if there were no firewall
- Firewalls are the most visible part of an installation to the outside, so they are the most attractive target for attack
 - Several layers of protection, called defense in depth, are better than relying on the strength of just a single firewall.



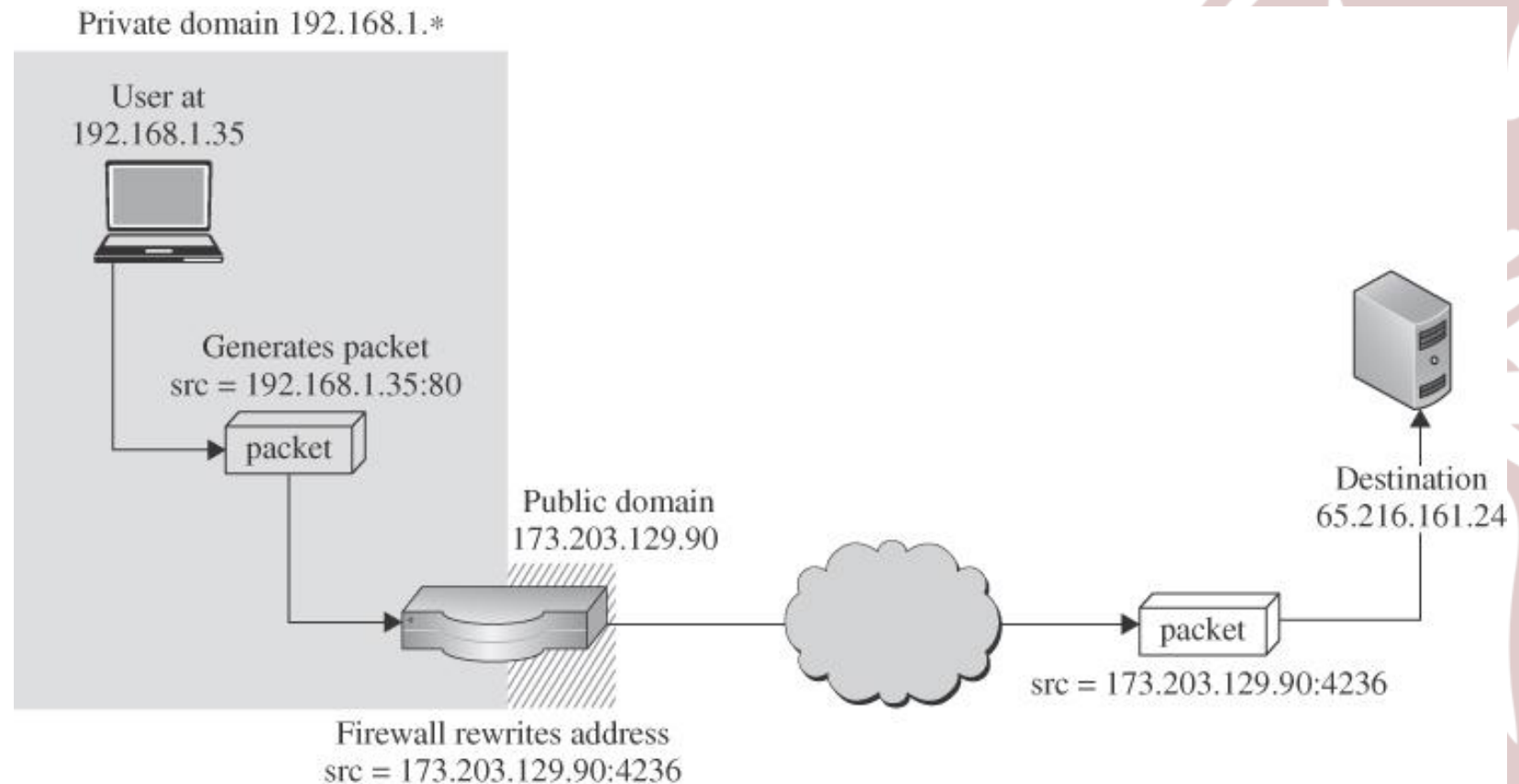
Firewall limitations (cont'd)

- Firewalls must be correctly configured
 - that configuration must be updated as the internal and external environments change,
 - firewall activity reports must be reviewed periodically for evidence of attempted or successful intrusion.
- Firewalls are targets for penetrators
 - is designed to withstand attack, it is not impenetrable.
 - Designers intentionally keep a firewall small and simple so that even if a penetrator breaks it, the firewall does not host further tools, such as compilers, linkers, loaders, and the like, to continue an attack.
- Firewalls exercise only minor control over the content admitted to the inside
 - inaccurate data or malicious code must be controlled by other means inside the perimeter.



Network Address Translation (NAT)

- To avoid exposure of internal IP addresses
- Internal IP addresses and IP header data can be used to infer on the network topology
- Furthermore, once released, these addresses will forever be known and exploitable by outsiders.



Intrusion Detection and Prevention

IDS

IPS



Intrusion Detection Systems (IDS)

A device, typically a separate computer, that monitors activity to identify malicious or suspicious events

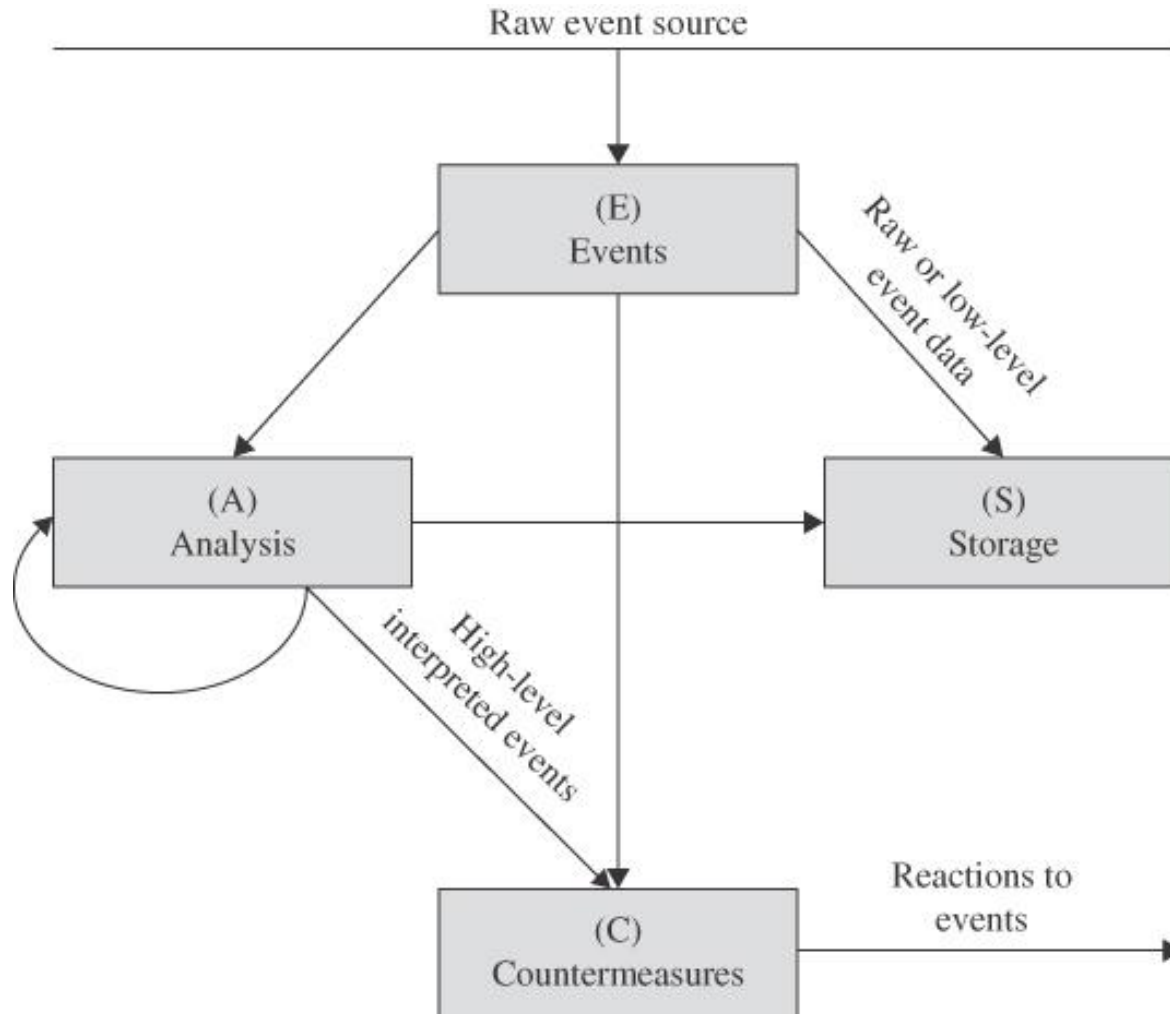
IDS can have a response function, e.g.,

- to alert a human team
- to isolate a suspected intruder and constrain access by electronically reconfiguring a network

A response system is called an intrusion protection system (IPS).



A model of an IDS



IDSs perform a variety of functions:

- monitoring users and system activity
- auditing system configuration for vulnerabilities and misconfigurations
- assessing the integrity of critical system and data files
- recognizing known attack patterns in system activity
- identifying abnormal activity through statistical analysis
- managing audit trails and highlighting user violation of policy or normal activity
- correcting system configuration errors
- installing and operating traps to record information about intruders

Type of IDSs

Signature-based IDSs

- perform simple pattern-matching and report situations that match a pattern (signature) corresponding to a known attack type.

Heuristic IDSs (or Anomaly based)

- build a model of acceptable behavior and flag exceptions to that model;
 - the administrator can mark a flagged behavior as acceptable so that the heuristic IDS will now treat that previously unclassified behavior as acceptable
- learn what constitute anomalies or improper behavior
 - The **inference engine** (by using ML/AI techniques) identifies pieces of attacks and rates the degree to which these pieces are associated with malicious behavior.

Signature-based Intrusion Detection

Signature Example

- port scan - might describe a series of TCP SYN packets sent to many different ports in succession and at times close to one another
 - nothing unusual in the first SYN, say, to port 80, and then another (from the same source address) to port 25. But as more and more ports receive SYN packets, especially ports that normally receive little traffic, this pattern reflects a possible port scan.
- ICMP packet with a data length of 65535 bytes
 - some implementations of the protocol stack fail
- **If a signature does not exist, the IDS doesn't work – e.g. Zero-days-attack**

Signature-based Intrusion Detection: pattern mismatch

Attacker try to modify attack patterns to avoid detection, e.g.

- insert spurious packets that the IDS will see
- shuffle the order of reconnaissance probes
- Change character set

Each of these variations could be detected by an IDS, but more signatures require additional work for the IDS, thereby reducing performance



Signature-based IDSs incorporating statistical analysis

This approach uses tools

- to obtain sample measurements of key indicators ,e.g.,
 - amount of external activity,
 - number of active processes,
 - number of transactions
- to determine whether the collected measurements fit the predetermined attack signatures.



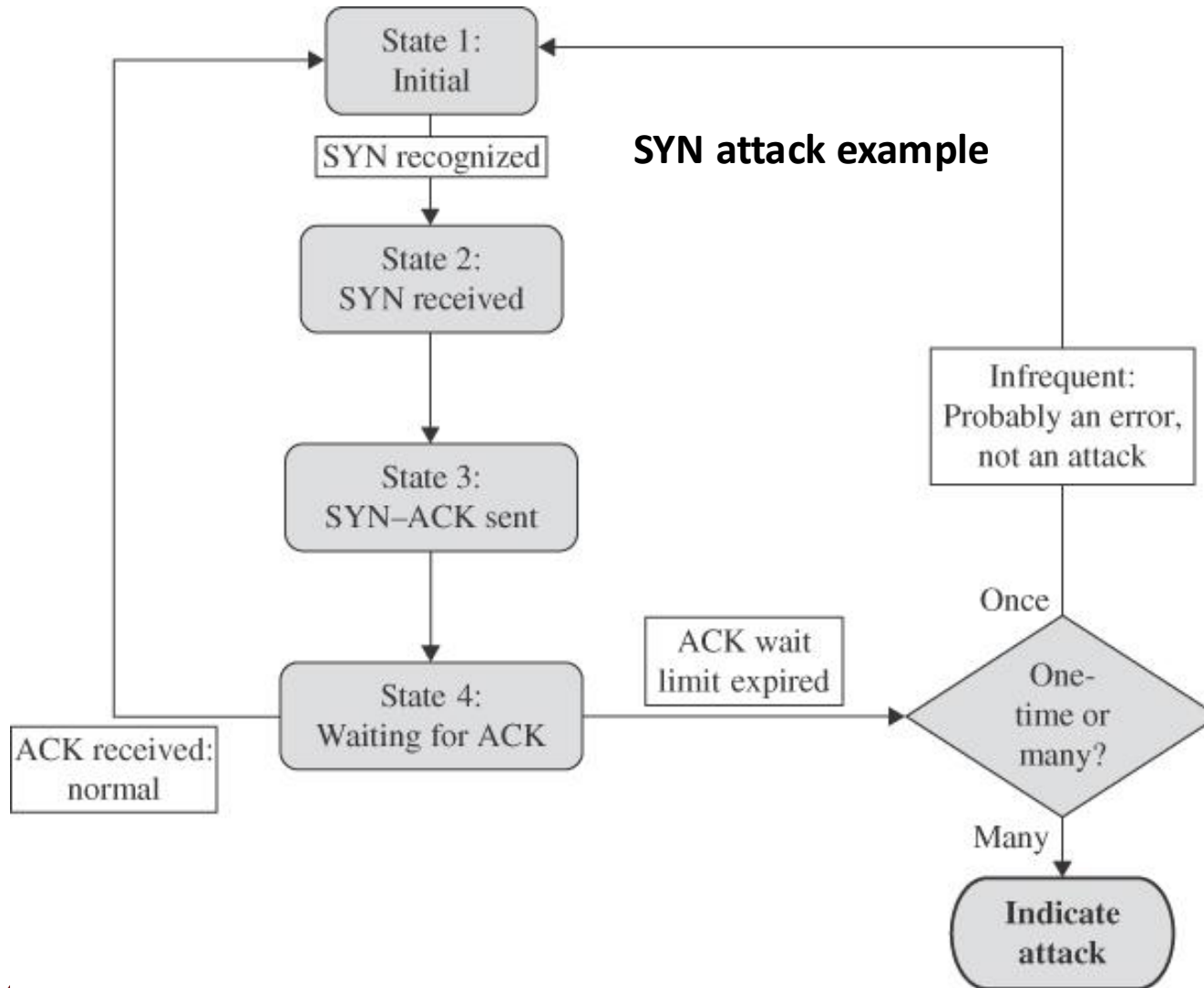
Signature-based IDSs: what they can and cannot detect

DoS attack like ping and echo-chargen are detectable

Not good for packet fragmentation attacks

- Teardrop attack depends on many packets that do not fit together properly, an IDS can notice that attack only after collecting information about all or a significant number of the packet fragments
 - fragmentation is a characteristic of most traffic, the IDS would need to maintain data on virtually all traffic, a challenging (but not impossible) task.
-
- SYN flood is recognized only by a profusion of unmatched SYN–ACK responses;
 - SYN–ACK is part of the three-way TCP handshake, it is a part of every communication session established, which makes it difficult for the IDS to classify the behavior as an attack.

Signature-based IDSs: Statefull protocol analysis



- Detection is difficult if the pattern to be matched is long or variable
- Different protocols with their different states and transition conditions are multiplied by the number of instances
 - for example, the number of concurrent TCP connections being established at any time
- maintaining the state for each connection became complex and costly

Heuristic-based Intrusion Detection

Looks for behavior that is **out of the ordinary**

- A system start clean with no intrusion, and it ended dirty, fully compromised
- Administrator tracing the use in which the system changed from clean to dirty build knowledge
- Little dirty events occur, occasionally at first and then increasing as the system became more deeply compromised
 - Any one of those events might be acceptable by itself
 - Their accumulation and their order and pace could be signals that something unacceptable is happening

The **inference engine** of an IDS continuously analyzes the system, raising an alert when

- the system's dirtiness exceeds a threshold
- a combination of factors signals likely malicious behavior



Heuristic-based Intrusion Detection – an example

- A network computer A starts to inspect other network computers, looking at which ones have storage areas (files) available to other network users
- A probes B computer, the IDS may classify that act as unusual, but B computer denies A access (no public file) and the IDS simply notes the denied access request
- Then A probes C, the **second attempt becomes more unusual**.
 - C has a file structure open to the network, and A obtains a directory listing of all accessible files on C → **IDS flags as suspicious**
 - A then tries to copy all of C files → **the IDS recognizes a likely attack** and triggers an alarm to an administrator.

Any of the actions A took is not significant by itself, but each piece of the accumulation leads to greater suspicion and finally an alarm

Inference Engine

State-based

- see the system going through changes of overall state or configuration, from clean to dirty
- try to detect when the system has veered into unsafe mode
- In the example: states would be probing (clean), probing again (not completely clean), listing contents (borderline), copying contents (certainly dirty)

Model-based

- work from a model of known bad activity - observe traffic or system feature that change over time – *see table II and III of the paper*
- the IDS raises an alarm when current activity matches the model to a certain degree
- Classify all activity in three categories: **good/benign, suspicious, or unknown**



Example of detection

- **Land attack:** an attacker sends spoofed SYN packet in which the source address is the same as the destination address. It is effective in some of the TCP/IP implementations.
 - The attack can be detected by considering the feature 'Land'. If the value of feature 'Land' is 1, it means that source and destination address are identical. Hence this feature is most important in recognizing this attack.
- **Teardrop** – see previous slides for description
 - Feature 'Wrong Fragment' which is the sum of bad checksum packets in a connection provides some clue about the malformed IP packets. Hence this feature is important in recognizing this attack.

Example of detection (cont'd)

- **Smurf** – see previous slides for description
 - This attack can be easily detected in the victim machine by looking at the huge number of ICMP echo replies to victim machine without sending any ICMP echo requests packets from the victim machine.
 - There are some feature such as
 - 'Service' (ICMP), 'Duration',
 - 'Dst host same srv rate' (used to find the percentage of connections to the same service and to the same destination IP address coming from attacker's machines)
 - 'Same srv rate' (used to find the percentage of connections to the same service and to the same destination IP address going from victim machine)
- which are useful in determining the total number of ICMP echo packet to victim machine within some duration of time and total ICMP reply packets from the victim machine within some duration of time.

Example of detection (cont'd)

- **Ipsweep:** An Ipsweep is used to determine which hosts are listening on the network by sending many ping packets. If a target host replies, the reply reveals the targets IP address to the attacker
- Attack Features:
 - total number of ping packets coming within a short duration of time
 - 'Duration', 'Service' (ICMP), 'Dst host same srv rate' (used to find the connections to the same service) and 'Flag' (used to find connection status) are important to find the total ping messages within short duration of time and current state of connection to detect the ipsweep attack

Protocol level inspection technologies

An IDS is said to operate at a particular network level or layer.

- For example, an IDS that detects malformed packets will not likely also be able to monitor application data because that would require the IDS to do all the work of reassembling packets to extract the application-level data

Thus, different IDSs, or different components of an IDS package, monitor a network at different levels.



- Read the paper *“A Detailed Investigation and Analysis of Using Machine Learning Techniques for Intrusion Detection”* for more examples



Heuristic-based IDS – Pro & Cons

- heuristic intrusion detection is limited by the amount of information the system has seen (to classify actions into the right category) and how well the current actions fit into one of these categories
- The advantage of heuristic intrusion detection is that systems learn over time



Front-end and Internal IDS

- Front-end
 - Watch all the incoming traffic
 - Frequently integrated into firewall
 - Visible hence Detectable → target of attack (for disabling them)
- Internal
 - Monitor the traffic from inside – good to determine insider attack or attacks originating from machine inside the perimeter
 - Can easily learn typical behavior of internal machines and users
 - E.g., a compromised machine can be instructed with legitimate traffic passing the front-end IDS to start an internal DoS attack or be part of a botnet.
 - Not visible → more well protected from outside



Host Based (HIDS)

HIDS - runs on and protects a single host against attack

- collects and analyzes data from
 - OS supplies approved and denied requests to access sensitive resources,
 - logs of applications run,
 - times and dates of actions,
 - other security-relevant data.
- The device either analyzes data itself or forwards the data to a separate machine for analysis and perhaps correlation with HIDSs on other hosts
- Is a process on a computer → detectable

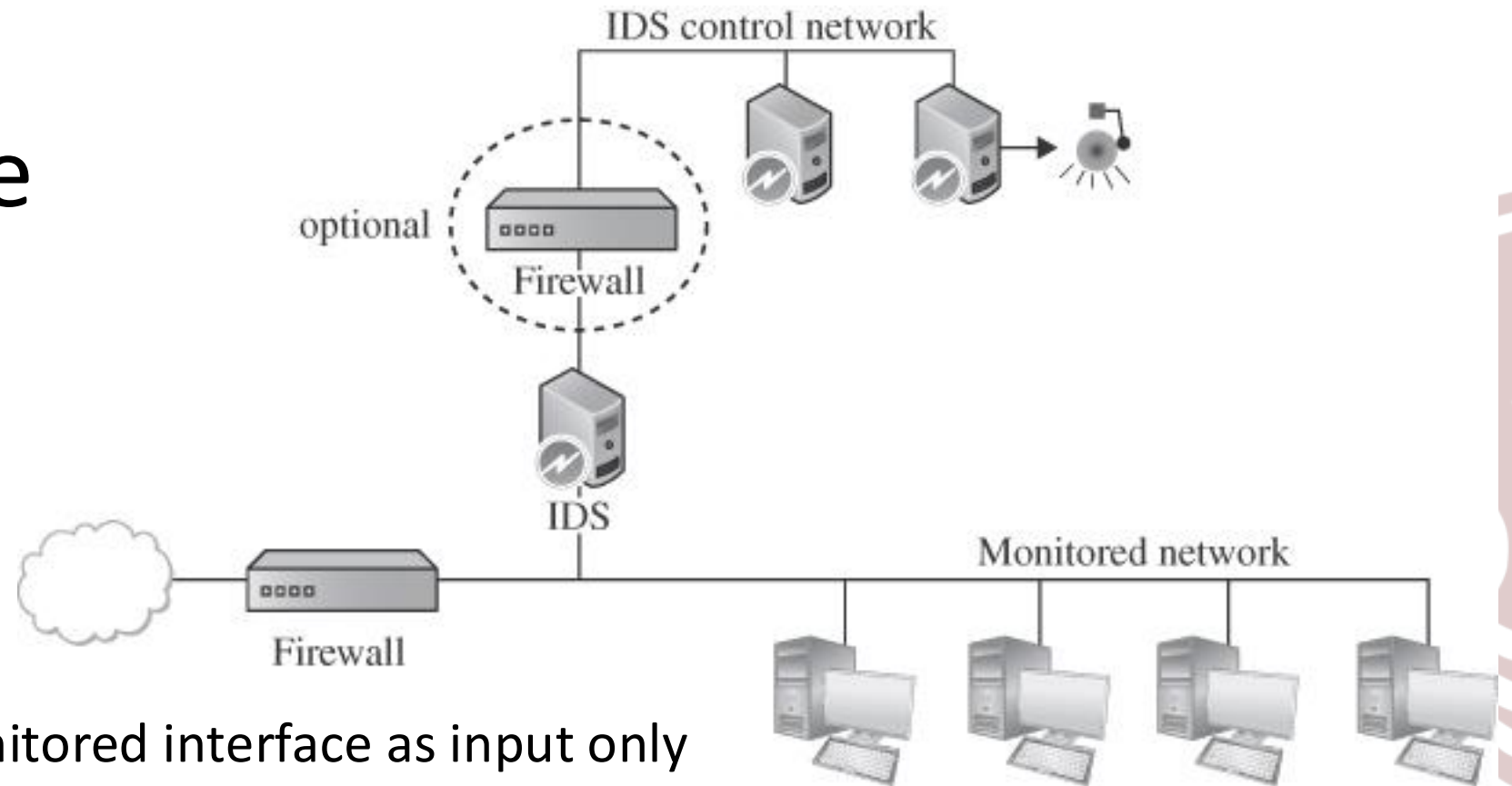


Network Based (NIDS)

- It receives data from
 - firewalls (if separate),
 - operating systems of the connected computers,
 - sensors such as traffic volume monitors and load balancers
 - administrative actors on the network
- A network IDS is better able to protect itself against detection or compromise than a host-based one because the network IDS can observe but never communicate on the network it is monitoring



Stealth mode



- The IDS uses the monitored interface as input only
 - it never sends packets out through that interface
 - Often, the interface is configured so that the device has no published address through the monitored interface; that is, no router can route anything directly to that address
- If the IDS needs to generate an alert, it uses only the alarm interface on a completely separate control network.

Goals for Intrusion Detection Systems

An IDS should be

- fast, simple, and accurate as well as rigorous and complete.
- detect all attacks with negligible performance penalty.

An IDS could use some—or all—of the following design approaches:

- Filter on packet headers.
- Filter on packet content.
- Maintain connection state.
- Use complex, multipacket signatures.
- Use minimal number of signatures with maximum effect.
- Filter in real time, online.
- Hide its presence.
- Use optimal sliding-time window size to match signatures.



Accuracy

- False positive:
 - raising an alarm for something that is not really an attack
 - Too many false positives means the administrator will be less confident of the IDS's warnings, perhaps leading to a real alarm's being ignored.
- False negative
 - not raising an alarm for a real attack
 - False negatives mean that real attacks are passing the IDS without action.
- The degree of false positives and false negatives represents the sensitivity of the system
- Most IDS implementations allow the administrator to tune the system's sensitivity to strike an acceptable balance between false positives and negatives



IDS Limitations

- look for known weaknesses, whether through patterns of known attacks or models of normal behavior
- sensitivity, which is difficult to measure and adjust. IDSs will never be perfect, so finding the proper balance is critical
- an IDS does not run itself; someone has to monitor its track record and respond to its alarms



Intrusion Prevention System (IPS)

- Block or stop harm - an IDS with a built-in response capability
- The response could include:
 - cutting off a user's access
 - rejecting all traffic from address a.b.c.d,
 - blocking all users' access to a particular file or program
- Four categories of responses
 - **Monitor**, collect data, perhaps increase amount of data collected.
 - **Protect**, act to reduce exposure.
 - **Signal an alert** to other protection components.
 - **Call a human**



Categories of responses

- Monitoring
 - Appropriate for studying the attacks
 - No response action to not be visible
- Protecting
 - increasing access controls, making a resource unavailable, blocking the network connection the attacker is using
 - protecting may be very visible to the attacker. Visible action may be exactly the right course if it causes the attacker to cease and go elsewhere
- Signaling
 - Rising an alert to other protection mechanisms



Protecting - Adaptive behaviour

Responses can be

- Continue to monitor the network.
- Block the attack by redirecting attack traffic to a monitoring host, discarding the traffic, or terminating the session.
- Reconfigure the network by bringing other hosts online (to increase capacity) or adjusting load balancers.
- Adjust performance to slow the attack, for example, by dropping some of the incoming traffic.
- Deny access to particular network hosts or services.
- Shut down part of the network.
- Shut down the entire network.

